Chapter 4

Technology and Security

Overview
- Domain 4 Exam Content Outline
- Learning Objectives/Task Statements
- Suggested Resources for Further Study
- Self-assessment Questions
- Chapter 4 Answer Key

Part A: Technology Principles
- 4.1 Technology Roadmaps and Enterprise Architecture
- 4.2 Operations Management
- 4.3 System Development Life Cycle
- 4.4 Data Life Cycle Management
- 4.5 Portfolio and Project Management
- 4.6 Technology Resilience and Disaster Response/Recovery
- 4.7 Emerging Technologies

Part B: Information Security Principles
- 4.8 Security Concepts, Frameworks, and Standards
- 4.9 Security/Risk Awareness and Training
- 4.10 Data Privacy and Data Protection Principles

Case Study
Chapter 4 Answer Key

Overview

IT risk management is distinct from IT operations or information security; however, it cannot be fully separated from these disciplines. To be effective in the management of IT risk, the risk practitioner must have a working understanding of key principles and concepts of information technology and security. This chapter aims to provide that foundational knowledge, including familiarity with computer hardware, software, and networking concepts; enterprise resiliency; secure system development; the importance of training and awareness in the modern workforce; and familiarity with data privacy.

This chapter represents 20% (30 questions) of the CRISC exam.

Domain 4 Exam Content Outline

A. Technology Principles

1. Technology Roadmaps and Enterprise Architecture
2. Operations Management
3. System Development Life Cycle
4. Data Life Cycle Management
5. Portfolio and Project Management

6. Technology Resilience and Disaster Response/Recovery
7. Emerging Technologies

B. Information Security Principles

1. Security Concepts, Frameworks and Standards
2. Security/Risk Awareness and Training
3. Data Privacy and Data Protection Principles

Learning Objectives/Task Statements

Upon completion of this chapter, the risk practitioner will be able to:

1. Collect, review, and evaluate existing information regarding the organization's business and information system environments.
2. Identify potential or realized impacts of information system risk to the organization's business objectives and operations.
3. Identify threats and vulnerabilities to the organization's people, processes, and technologies.
4. Evaluate threats, vulnerabilities, and risk to create information system risk scenarios.
5. Maintain or establish the information system risk register and incorporate it into the enterprise-wide risk profile.
6. Assist key stakeholders in the selection of risk appetite and tolerance thresholds and the impact on business objectives.
7. Promote a risk-aware culture by contributing to the development and implementation of security/risk awareness and training.
8. Conduct a risk assessment by analyzing information system risk scenarios and events to generate a risk score/rating.
9. Identify the current state of existing controls and evaluate their effectiveness for information system risk treatment.
10. Determine if risk exceeds appetite and tolerance thresholds to recommend treatment options and rectify concerns.
11. Review the results of risk and/or control analysis to assess any gaps between current and desired states of the risk environment.
12. Collaborate with risk owners on the development of risk treatment plans.
13. Collaborate with control owners on the selection, design, implementation, and maintenance of controls.
14. Validate that risk responses have been executed according to risk action plans.
15. Define, implement, and refine key risk indicators (KRIs).
16. Collaborate with control owners on the identification and refinement of key performance indicators (KPIs) and key control indicators (KCIs).
17. Monitor and analyze key risk indicators (KRIs), key performance indicators (KPIs), and key control indicators (KCIs).
18. Review the results of control assessments to determine the adequacy, effectiveness, and maturity of the control environment.
19. Conduct aggregation, analysis, and validation of risk and control data.
20. Report relevant risk and control information to applicable stakeholders to facilitate risk-based decision-making.
21. Evaluate emerging technologies and changes to the environment for threats, vulnerabilities, and opportunities.
22. Evaluate alignment of business practices with risk management frameworks, standards, and regulations.
23. Facilitate tabletop exercises to verify and identify gaps in risk scenarios, capabilities, and responses.

Suggested Resources for Further Study

Breaux, T.; *An Introduction to Privacy for Technology Professionals*, International Association of Privacy Professionals, USA, 2014

ISACA, *ISACA Privacy Principles and Program Management Guide*, USA, 2016

ISACA, *Cybersecurity Fundamentals Study Guide, 3rd Edition*, USA, 2021

Self-assessment Questions

The CRISC self-assessment questions provide an understanding of the type and structure of questions that have typically appeared on the exam. Questions are written in a multiple-choice format and designed for one best answer. Each question has a stem (question) and four options (answer choices). Many times, a question will require the candidate to choose the **MOST** likely or **BEST** answer among the options provided.

1. Which of the following business requirements **BEST** relates to the need for resilient business and information systems processes?

   A. Effectiveness

   B. Confidentiality

   C. Integrity

   D. Availability

2. An information system that processes weather forecasts for public consumption is **MOST** likely to place its highest priority on:

   A. nonrepudiation.

   B. confidentiality.

   C. integrity.

   D. availability.

3. The **BEST** control to prevent unauthorized access to an enterprise's information is user:

   A. accountability.

   B. authentication.

   C. identification.

   D. authorization.

4. Which of the following controls **BEST** protects an enterprise from unauthorized individuals gaining access to sensitive information?

   A. Using a challenge response system

   B. Forcing periodic password changes

   C. Monitoring and recording unsuccessful logon attempts

   D. Providing access on a need-to-know basis

5. Which of the following defenses is **BEST** to use against phishing attacks?

A. An intrusion detection system

B. Spam filters

C. End user awareness

D. Application hardening

Chapter 4 Answer Key

Self-assessment Questions

1. A. Effectiveness deals with information being relevant and pertinent to the business process and being delivered in a timely, correct, consistent, and usable manner. While the lack of system resilience can in some cases affect effectiveness, resilience is more closely linked to the business information requirement of availability.

   B. Confidentiality deals with the protection of sensitive information from unauthorized disclosure. While the lack of system resilience can affect data confidentiality, resilience is more closely linked to the business information requirement of availability.

   C. Integrity relates to the accuracy and completeness of information and to its validity in accordance with business values and expectations. While the lack of system resilience can in some cases affect data integrity, resilience is more closely linked to the business information requirement of availability.

   D. Availability relates to information being available when required by the business process—now and in the future. Resilience is the ability to provide and maintain an acceptable level of service during disasters or when facing operational challenges.

2. A. Nonrepudiation refers to the ability to verifiably prove the originator of data, which is unlikely to be of importance for weather forecasts that are rendered accurately.

   B. Keeping data confidential would be at odds with the business purpose of a system designed to provide data for public use.

   C. A system that delivers weather forecasts is likely to place its highest priority on the integrity of the data. The risk practitioner should keep in mind that whether a forecast turns out to be accurate in its prediction is distinct from whether the data was accurately represented.

   D. Availability of data is likely to be a lower priority for a weather-forecasting system than the accuracy with which the data is presented.

3. A. User accountability does not prevent unauthorized access; it maps a given activity or event back to the responsible party.

   B. Authentication verifies the user's identity and the right to access information according to the access rules.

   C. User identification without authentication does not grant access.

   D. Authorization determines the permissions and privileges eligible to a given user identity after authentication, which will not restrict the successful breach of a valid identity.

4. A. Verifying the user's identification through a challenge response does not completely address the issue of access risk if access was not appropriately designed in the first place.

   B. Forcing users to change their passwords does not guarantee that access control is appropriately assigned.

   C. Monitoring unsuccessful access logon attempts does not address the risk of appropriate access rights.

D. **Physical or logical system access should be assigned on a need-to-know basis (legitimate business requirements) and in ways that incorporate the least privilege and separation of duties (SoD).**

5. A. An intrusion detection system (IDS) does not protect against phishing attacks because phishing attacks usually do not have the same patterns or unique signatures.

   B. While certain highly specialized spam filters can reduce the number of phishing emails that reach their addressees' inboxes, they are not as effective in addressing phishing attacks as end user awareness.

   C. **Phishing attacks are a type of social engineering attack and are best defended by end user awareness training.**

   D. Application hardening does not protect against phishing attacks because phishing attacks generally use email as the attack vector, with the end user, not the application, as the vulnerable point.

Part A: Technology Principles

IT has evolved from a support service that offered competitive advantage to a business enabler whose loss would effectively cripple operations. This part introduces the risk practitioner to a series of concepts and principles that are widely known within IT circles and have implications for the management of information risk.

4.1 Technology Roadmaps and Enterprise Architecture

Key Takeaways

- Enterprise architecture helps organizations determine whether their technology plans are supporting their business goals.
- Technology roadmaps provide guidance on pursuing selected architectures.
- Maturity models offer insight into how far enterprises have progressed.

Strategic management of enterprise information technology begins with an enterprise-level understanding of the network and information architecture. Enterprise architecture (EA) delivers a view of the current state of IT, establishes a vision for a future state, and generates a strategy to move from current to future conditions that minimizes business disruption. The enterprise view of IT demonstrates links between IT and organizational objectives, and produces a view of current risk and controls to answer or enable answering four basic questions:

- Are we doing the right things?
- Are we doing them the right way?
- Are we getting them done well?
- Are we seeing expected benefits?

These "Four Are's," as discussed in section 1.1 Strategy, Goals, and Objectives, comprise a cycle of examination, evaluation and adjustment. The questions and their answers serve as important, continuous feedback to implementation of enterprise IT strategy under an approved architecture, and ensure that IT projects deliver their intended value. An EA typically includes business functions or capabilities, human roles, the physical structure of the organization, key business applications, data stores, data flows, platforms, hardware, and network or communications infrastructure. In short, an EA frames how information enables the organization to do whatever it does.

Because EA is a cycle, there is no point at which the architecture is fully settled. EA enables enterprise operations, and operations change with business conditions, so the EA will also change over time. At each point in the cycle where one of the iterative questions is answered in the negative, a change is needed. The EA generally provides guidance on what new short- and long-term goals align with meeting business needs.

A technology roadmap is the name given to the planning process that links those goals with specific technology solutions. In some cases, the roadmap may include forecasting for emerging capabilities that do not yet exist as commercial products.

Although an EA can be developed independently of any reference material, organizations commonly leverage EA frameworks to facilitate the process. All EA frameworks provide structured guidance across four key topics:

- **Documentation—**Ways to present the architecture in terms of particular taxonomy or nomenclature depending on the audience
- **Notation—**Ways to visualize the architecture in a standardized way
- **Process—**The goals, inputs, actions, and outputs that occur in building architecture, commonly grouped upward into phases and supported from below by techniques and practices
- **Organization—**Skill sets, training, and approaches to governance needed for the architecture

Different EAs address these topics differently. Architecture frameworks commonly used in commercial organizations include:

- The Open Group Architecture Framework (TOGAF)
- The Zachman Framework
- US Department of Defense Architecture Framework (DODAF)
- US Federal Enterprise Architecture Framework (FEAF)
- Sherwood Applied Business Security Architecture (SABSA)

Other EAs exist for specialized purposes such as telecommunications. A single enterprise cannot embrace more than one EA, but different stakeholders may require or benefit from different technology roadmaps based on the short- and long-term goals of particular interest to their areas of focus.

Risk management requires a complete and thorough assessment of the risk to each element of a system. The risk associated with an IT system is a composite of the risk associated with each element within the system. Accordingly, risk in any one location can affect the security of all other areas, and a vulnerability on one system may affect the security of all other systems to which it connects.

Forecasting the issues can be useful in anticipating future controls and operational technology. For instance, it may be apparent that passwords will need to be supplemented with multifactor authentication (MFA) when a previously closed system is connected to a globally accessible extranet portal.

In environments in which an EA is either immature or absent, the risk practitioner must place greater emphasis on the use of technology-specific assessments as a means of building a piecemeal vision of current IT risk. Evaluation of risk against an established EA, therefore, yields both greater efficiency and more complete understanding of the risk environment, while the development of meaningful roadmaps helps the risk practitioner anticipate changes to the environment based on the stated goals and preferences of management.

4.1.1 Maturity Models

Since the 1980s, enterprises have looked for ways to baseline their standing in specific areas using survey-based frameworks. The goal of these maturity models is not to dictate how something should be done but rather what outcomes are desirable. By reviewing what they are doing relative to published baselines,

organizations can gauge their progress in building mature programs as envisioned by leading enterprises and industry peers.

Maturity models designed specifically for EA have been published by numerous organizations over time, including Capability Maturity Model Integration (CMMI), NASCIO (EAMM), and Gartner (ITScore). The Open Web Application Security Project has published a Software Assurance Maturity Model (OWASP SAMM), and the NIST Cybersecurity Framework (CSF) (see section 3.5 Control Frameworks, Types, and Standards) has been used as a maturity model for cybersecurity.

While specific models vary, they generally begin at a level where the program is either nonexistent or entirely notional, lacking any practical implementation. From there, organizations move through levels that include reaction, operation as distinct functions, and integration as part of overall enterprise operations. This overall approach is consistent with principles of total quality management (TQM) and continuous process improvement (CPI), where the goal is to reach an optimizing or efficient level of operations through iteration and refinement.

In considering enterprise risk, the risk practitioner should investigate if an EA is in place and, where possible, assess the EA to determine its maturity. Significant effort, resources, and time are required to develop an EA, so it is not uncommon for the risk practitioner to discover that the EA either has not been formally established or is at a low maturity state. Where an EA has been selected, look to the technology roadmap to see how far the process has progressed toward implementation and meeting stated short- and long-term organizational goals.

Originating from the assumption that greater monitoring means less risk, maturity models tend to promulgate controls at increasing rates. TQM and CPI originated in factory production, where physical processes tended to limit the degree of monitoring that might be achieved. No such limits arise organically in information-centric organizations, so the potential exists to expand monitoring to such a degree that the results of monitoring exceed an organization's ability to act upon them.

The nature of cybersecurity risk is distinct from quality problems in manufacturing, and a highly monitored environment may nonetheless fail to adequately manage risk. In recent years, some industries have moved away from maturity models when looking at cybersecurity programs. However, this is not a universal trend. For example, the US Department of Defense developed the Cybersecurity Maturity Model Certification (CMMC) program to assess participants in the US Defense Industrial Base against established cybersecurity requirements.

The alternative to capability maturity models is an approach that targets attention on measurements and controls that align with an organization's greatest known areas of risk. Organizations pursuing this approach believe that sustained commitments to cybersecurity, such as red team engagement (see section 3.11.2 Control Assessment Types), can lead to a proactive posture where security is truly part of daily operations. At present, there is no consensus around whether this dynamic represents an improvement over maturity models or instead defines "maturity" according to different criteria than those applied in the prevailing generation of models.

4.2 Operations Management

Key Takeaways

- Risk arises from IT components, concepts, and practices.
- To be able to meaningfully interact with IT operations staff and thereby control this risk, risk practitioners should be familiar with these concepts.
- Networking, supply chains, and the implications of personally owned devices are among the most important topics to understand.

The risk practitioner is not expected or required to be a technical expert in the design, implementation, or support of individual IT systems or applications. However, strong knowledge of general IT concepts is invaluable. The identification, assessment, and monitoring of IT risk, along with recommendation of appropriate responses to the risk that is identified, require close and ongoing interaction with IT staff. Accordingly, the risk practitioner should have a working knowledge of networking, applications, and other aspects of IT that appear within the organizational IT infrastructure.

Particular areas of concern are identified for the risk practitioner in each of the following sections. These areas may encompass or substantially relate to particular or commonly identified threats, vulnerabilities or business impacts, and are presented in the context of the risk management process.

4.2.1 Hardware

IT systems and business processes rely on hardware—the equipment and devices that process, store, and transmit data. Hardware includes many devices, such as:

- Desktop, laptop, or mobile computers, which include:
  - Central processing units (CPUs)
  - Graphics processing units (GPUs)
  - Motherboards
  - Random access memory (RAM)
  - Read-only memory (ROM)
- Networking components (switches, routers, etc.)
- Security components (firewalls, intrusion detection systems, etc.)
- Peripherals (keyboards, monitors, etc.)
- Industrial equipment enabled for networking (“smart” appliances/Internet of Things devices [IoT])

Areas of concern associated with hardware include:

- Obsolescence
- Poor maintenance
- Misconfiguration
- Use of default credentials
- Lack of secure configurations
- Unnecessary services, ports, and protocols running on the system
- Missing or inaccurate documentation
- Physical loss or theft
- Data loss due to insecure disposal
- Unauthorized capture of traffic (“sniffing”)
- Physical access
- Component or system failure
- Use without authorization
- Inaccurate asset inventory

In environments where users are permitted to have their personal mobile phones with them for use throughout the day, it is important to acknowledge that these devices may serve as unwitting channels by which data can be exfiltrated if they are compromised.

Because their small size, frequent use, and the potential for quick resale on secondary markets at relatively high prices, mobile phones are among the most easily damaged, stolen, and lost devices. Business processes that expect or require staff to use their personal mobile phones for communication may be affected by impacts to these devices, even though they are outside the scope of organizational ownership. This potential for business impact arising from personal loss is especially serious under paradigms that use personal mobile devices for tokens in MFA (see section 4.8.5 Access Control).

Supply Chain Management

In recent years, several types of hardware have been intentionally infected with security vulnerabilities during the manufacturing or delivery process. These breaches have been found on network devices, point-of-sale terminals, applications, and smartphones from numerous countries and vendors. Despite general awareness of the threat, such vulnerabilities are not easy to detect.

Risk practitioners should be aware of the risk of purchasing infected equipment and encourage their organizations to use trusted vendors or suppliers whenever possible. Purchasing equipment that has been tested and evaluated by an external entity using an internationally approved process, such as the Common Criteria (ISO/IEC 15408), may provide a higher level of confidence that the equipment is secure. Internal IT staff should also validate that maintenance hooks, which allow vendors to gain access to systems for monitoring purposes, are documented and either secured or eliminated. When performing administration of hardware devices, a secure channel should be used with strong authentication required.

4.2.2 Software

Software refers to the programming used to cause hardware to carry out specific functions or activities in ways that can be reconfigured without electrical intervention. The general concept of software is very broad and includes operating systems (OSs), utilities, drivers, firmware, middleware, application programming interfaces (APIs), applications, database management systems (DBMS), and networking tools that manage data, interface between systems, provide user interfaces to hardware, and process transactions on behalf of the user.

Areas of concern associated with software include:

- Logic flaws or semantic errors (“bugs”)
- Lack of patching
- Inadequate or ungoverned access control
- Disclosure of sensitive information
- Improper modification of information
- Loss of source code
- Lack of version control
- Processing of input and output without validation
- Unnecessary services and protocols running on the system
- Unnecessary ports open on the system
- Lack of a security software development life cycle
- Lack of software updates to the most current version

Operating Systems

The OS is the core software that allows the user to interface with hardware and manages all system operations. The OS manages access to system resources and controls the behavior of system components.

Areas of concern associated with the OS include:

- Unpatched vulnerabilities
- Poorly written code (buffer overflows, etc.)
- Complexity
- Misconfiguration
- Weak access controls
- Lack of interoperability
- Uncontrolled changes
- Unnecessary services and protocols running on the system
- Unnecessary ports open on the system
- Kernal-level vulnerabilities (e.g., rootkits, hypervisor escapes, etc.)

- Back doors for open-source OS
- End of support for OS on legacy systems

Currently, most traditional computers (desktops and laptops) use versions of Windows, macOS, or Linux, while mobile devices commonly run Apple iOS or Google Android. These systems are subject to periodic version updates that may affect APIs and subsystems in ways that can impact third-party applications. Access to APIs may be available to third-party developers with minimal oversight. Risk also arises from unsecured access to APIs within an organization's own network, which creates risk associated with unauthorized access.

No commercially available OS is absolutely secure; therefore, regardless of the underlying platform, it is necessary to implement strict controls over changes, patches, and configurations. Where practical, systems should be hardened to disable unnecessary services and default accounts, and passwords should always be changed. Deployment of security patches is also important and should be subject to a patch management process that identifies, tests, and schedules implementation as quickly as possible. However, testing should not be skipped to expedite patching, because it is possible for a patch to create negative effects on systems. Even with rigorous testing, after a patch has been implemented, it should be monitored to ensure that all related systems, utilities, and applications are still working correctly.

For example, in 2024 global cybersecurity company CrowdStrike pushed an update to its Falcon sensor that was faulty. This flaw resulted in a global outage of Windows-based machines, resulting in impacts to multiple sectors including air travel, government, finance, healthcare, retail, and more.[38] Root cause analysis discovered that the update had not undergone routine patch management processes.[39]

Risk practitioners should keep in mind that these goals may be largely unattainable in environments where personal devices are included within the scope of operations. Personal devices may update automatically, or users may choose to update them as soon as possible to gain access to new features. Any reliance on the capabilities of personally owned devices introduces the possibility of risk arising from changes or impacts outside organizational control.

Applications

Applications are the face of the information system and the mechanism by which most users access information, perform transactions, and use system features. Most functions are accomplished by applications, which interact with the OS using APIs or other programming methods. When applications are negatively impacted, the result is often a loss of value to the enterprise.

Areas of concern associated with applications include:

- Poor or no data validation
- Exposure of sensitive data (i.e., lack of encryption/obfuscation)
- Improper modification of data
- Logic flaws (i.e., logic errors)
- Software bugs (i.e., coding errors)
- Lack of logs
- Lack of version control
- Loss of source code
- Weak or lack of access control
- Lack of operability with other software
- Back doors
- Poor coding practices
- Lack of governance over how data is stored
- Vulnerable container images
- Misconfigured serverless functions

Application risk is often due to flaws or bugs in the coding of the application, including software developed by an organization for internal use and programs written by third-party developers. Countermeasures to web application vulnerabilities are related to proper design, coding, and testing. The Open Web Application Security Project (OWASP)[40] and similar resources list common web application vulnerabilities and provide direction on how to mitigate and test for such vulnerabilities. See Chapter 2 Risk Assessment for more information.

Risk practitioners should also consider the potential for application risk to arise from software updates. In mobile computing, it is not unusual for a major version release to change or even remove functionality. Updates to mobile software also may not be truly optional in some cases, with vendors ending support for prior versions after a new release or even creating conditions under which hardware integrations no longer function without an upgrade. In some circumstances, this can mean sudden loss of features that impact production or serve to manage risk. As noted, the potential for negative impacts is particularly high when relying on personally owned devices, and the risk practitioner should ensure that managers opting to leverage such devices for competitive advantage are aware of the risk and formally accept it.

Databases

Where large amounts of information need to be stored and retrieved on a regular basis, organizations commonly use databases. Since databases tend to contain critical and sensitive information that supports business operations, they make tempting targets for malicious actors. They also tend to be difficult and expensive to recover without loss. For both reasons, it is important that databases be properly secured.

Database security is provided through the following:

- Encryption of sensitive data in the database
- Use of database views to restrict information available to a user
- Secure protocols to communicate with the database
- Content-based access controls that restrict access to sensitive records
- Restricting administrator-level access
- Efficient indexing to enhance data retrieval
- Resilient architecture (shadowing, mirroring, clustering)
- Backups of transaction journals (remote journaling)
- Encryption of backups
- Referential integrity
- Entity integrity
- Validation of input
- Defined data fields (schema)

Database servers should be placed behind significant protective measures and not be directly accessible from outside organizational boundaries.

Software Utilities

Various forms of software utilities, including device drivers and application middleware, provide the vital bridges between hardware and applications. Drivers translate application commands into formats that hardware can understand, and like all translation, this is a trusted role.

Areas of concern associated with utilities and drivers include:

- Lack of drivers
- Use of outdated or unpatched drivers
- Use of insecure components (older encryption algorithms)
- Unpatched vulnerabilities

Compromised drivers may interfere with proper operations of hardware by altering intended commands to yield different results than anticipated or failing to deliver any instructions at all. In environments that include connections between information systems and physical machinery, incorrect behavior by a utility program may result in unexpected behavior, including imprecision or excessive wear. Organizations should take care to obtain utilities only from trusted sources and ensure that they are tested with sufficient rigor to meet the risk appetite before they are moved into production.

4.2.3 Environmental Controls

Environmental controls include power and heating, ventilation, and air conditioning (HVAC) systems that support IT operations. When deprived of environmental services, computer systems may immediately shut off (as with loss of power) or endure under conditions that can lead to electrical or mechanical errors (as with loss of ventilation, unregulated temperature, or power levels slightly below electrical requirements). These impacts may in turn affect business processes by interrupting processes or causing them to be completed incorrectly. Areas of concern associated with environmental controls include:

- Power effects
  - Utility power
    - Surges or spikes
    - Sags or brownouts
    - Faults
  - Generators
    - Insufficient capacity
    - Poor maintenance
    - Latency or spin-up time
  - Batteries
    - Depletion
    - Mechanical failure
    - Incorrect placement
- HVAC
  - Overheating
  - Humidity problems
    - Corrosion and condensation (high humidity)
    - Static (low humidity)
  - Clogged filters
  - Lack of maintenance
- Water
  - Loss of water needed for cooling systems
  - Flooding/leakage
- Health and safety issues
- Physical access

Heat and electricity are the two most essential environmental factors facing computing environments. However, physical security of operational areas and supporting equipment can contribute significantly to current risk. Access to sensitive areas should be restricted to protect systems and staff members. Fire is also a substantial threat and should be addressed with manual or automated protection measures sufficient and suitable for the risk appetite and risk tolerance of management.

4.2.4 Networks

Much of the value associated with computing power today arises from bringing information from one place to another for collaboration, distribution, efficient processing or other purposes. When two or more computers are brought into connection with one another, the result is a network.

Networks take many forms and can be made up of a variety of specialized devices, including cabling, repeaters, switches, routers or gateways, firewalls, and wireless access points. They range in size from two devices to the global network of interconnected devices that we call the internet and many variants in between, all of which operate on essentially the same principles.

Networks warrant special consideration in IT risk management. In part, this is because they are often the targets or channels used to attack systems or applications; however, the network itself is often essential to business operations, and many business processes rely on its continued availability as a precondition for most business processes.

Networks are used for many purposes, including:

- Transferring data between individuals
- Transferring data between applications
- Controlling and monitoring of remote equipment (such as industrial or supervisory control and data acquisition [SCADA] networks)
- Backing up data
- Enabling communication between end user devices (e.g., Bluetooth)

When assessing networks, the risk practitioner should consider:

- Network configuration and management, including the criticality of network operations
- Network equipment protection
- The use of layered defense (defense in depth)
- Suitable levels of redundancy
- Availability of bandwidth sufficient for intended use cases
- Use of encryption for transmission of sensitive data
- Management of encryption keys
- Damage to cabling and network equipment
- Eavesdropping on communications through physical tapping or logical interception (e.g., man in the middle)
- Choices and documentation of network architecture
- Management of flow of information via network devices like firewalls, routers, switches, etc.

Protocols

Networks send signals using a variety of physical methods. However, all of them have the same result: data sent by one participating device is delivered to another to process. These data typically comprise messages but are broken into small pieces (packets) to allow multiple messages to traverse networks at the same time. For applications to receive data successfully, a series of intermediary steps is needed to interpret the binary code received by the destination host—specifically, what portion of the transmission comprises data that were originally sent versus header data that was added on to help the transmission reach its destination?

Similar to how one understands how to interpret the writing on postcards, destination hosts can answer this question by knowing in advance what format the received data is meant to take, which is a function of how it was packaged and processed. These rules for packaging and processing of network traffic are called protocols.

The TCP/IP and OSI Models

In the 1960s, the US Department of Defense (DoD) began working on ARPANET, a networking project designed as an experiment of connecting and maintaining communication between all military units, even during war time. It was eventually rolled into other projects, creating an entire DoD model.

However, the work did not begin as an integrated effort. Because of this disparate work, solutions were needed to ensure that devices could reliably communicate. In the late 1970s, the International Organization for Standardization (ISO) began creating such a standard, which became a framework of standards that defined how networks would function. Ultimately, the communication process was defined in layers in the ISO Open Systems Interconnection (OSI) model.

Some significant requirements of the ISO OSI model project include:

- Changing one layer of the OSI model cannot affect other layers.
- Define the functions that occur at each layer.
- Standardize the network components to allow multiple-vendor development.
- Allow communication among various types of network hardware and software.

The OSI model has seven layers that define the functions of the network protocols. All OSI model layers are software, including the layer that is named physical. **Figure 4.1** shows the layers of the OSI model.

Figure 4.1—OSI Model

Layer	Description
Layer 7	Application
Layer 6	Presentation
Layer 5	Session
Layer 4	Transport
Layer 3	Network
Layer 2	Data Link
Layer 1	Physical

Source: ISACA, *Networks & Infrastructure Fundamentals Study Guide*, USA, 2021

It is important to note that the layers are numbered in descending order. The corresponding layer number is an important identifier because the layers are often referred to by their numbers and not just their names.

Figure 4.2 shows the OSI model with information about each layer.

Figure 4.2—Description of OSI Model Layers and Piece of Data

Layer	Used In	Process	What	Actions	Called	Note
7	Application	Application	Chunk of data	Process	Chunk of data	File, print, message, database and application services
6	Application	Presentation	Chunk of data	Translate	Chunk of data	Data transmission
5	Application	Session	Chunk of data	Prepare	Chunk of data	Dialog control—maintains, tracks, and closes sessions between applications
4	Host-to-host Communication	Transport	Chunk of data	Divided into pieces Given header data for transport layer protocol (usually TCP or UDP)	Segment protocol data unit (PDU) is maintained as the generic name	At each layer the unit name changes so you know where the data is in the encapsulation process
3	Host-to-host Communication	Network	Segment is passed here	Network layer protocol, typically Internet Protocol (IP), is added in the encapsulation process	Layer	
2	Local and Physical Network	Data Link	Packet is passed here	Layer (typically Ethernet) adds its header	Frame	

Layer	Used In	Process	What	Actions	Called	Note
1	Local and Physical Network	Physical	Frame is passed here	Put onto the wire	Bits	Being transmitted as bits of the medium being used

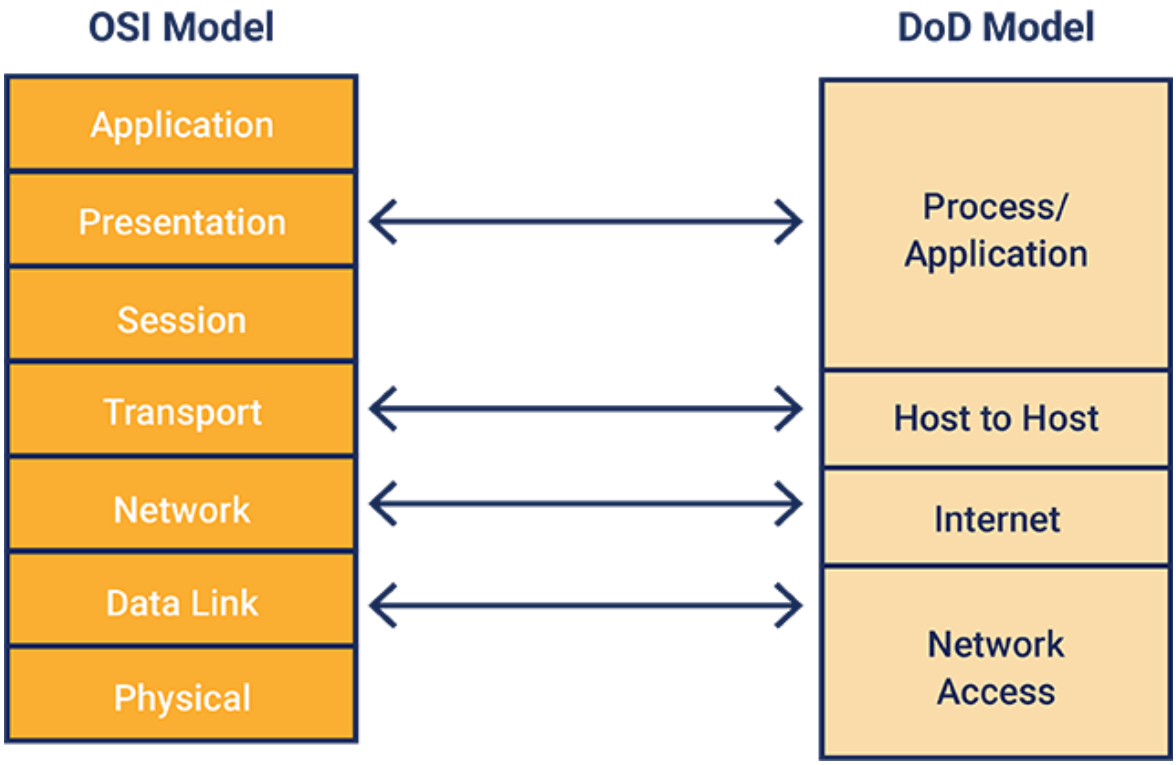
Source: ISACA, *Networks and Infrastructure Fundamentals Study Guide*, USA, 2021

The OSI model is known as a reference model, meaning that it helps explain how a hypothetical protocol would work; it was not intended to be implemented in its strictest form. Instead, it was the DoD model that was adopted, transforming into a set of protocols now commonly known as the Transmission Control Protocol/Internet Protocol (TCP/IP) suite. The functions of the seven layers of the OSI model are implemented in the TCP/IP suite as four layers (**figure 4.3**).

TCP/IP is a name given to a whole suite of protocols, of which TCP and IP are only two. Many other protocols are included, such as User Datagram Protocol (UDP), used for "best effort" transmissions, or Hypertext Transfer Protocol (HTTP), which renders webpages at the application layer. Protocols at higher levels of the suite stack rely on those at lower levels, and the two primary transport layer protocols (TCP and UDP) also offer several ports that allow systems to maintain multiple lines of communication at once.

There are protocols that exist outside of the TCP/IP suite; however, these are rarely used currently, essentially limited to highly specialized or legacy applications. TCP/IP is the protocol suite on which internet connectivity is based and sustained, and virtually all network-enabled software uses it.

Figure 4.3—OSI Association With the DoD Model



Source: ISACA, *Computing Fundamentals Study Guide*, USA, 2021

Cabling

Even as wireless networking has proliferated, physical links between systems continue to be of primary importance for many applications, including connecting devices subject to considerable interference and establishing high-speed links between core devices. Cabling comes in several forms including unshielded twisted pair (UTP), coaxial, and optical fiber. Each type of cable has its own benefits and vulnerabilities, and risk practitioners should have a basic understanding of these traits to ensure that the appropriate cabling is being used for the risk appetite and risk tolerance associated with the communications required.

UTP is prevalent in physical networks and is graded according to its specific speed ratings and attenuation potential. The least expensive option used for many local area networks (LANs) is UTP cable with a grade of Category 5e (CAT5e) or Category 6 (CAT6). Some vendors offer Category 7 (CAT7) and Category 8 (CAT8), which reduce noise and crosstalk for ultra-high-speed communication; strictly speaking, these are both shielded twisted pair (STP) variants, though they are virtually identical to UTP in appearance. For connections between networks over long hauls (such as internet connectivity), cabling is typically either coaxial or optical fiber, depending on the provider.

Areas of concern for the risk practitioner regarding cabling include:

- Physical security of cabling
- Cable exceeding the approved length of the cable runs (100 meters for CAT5e, 55 meters for CAT6)
- Protection from damage to cabling (conduit)
- Use in an area of high radio frequency interference (RFI), which may require shielding
- Use of cable that is not of suitable standard (e.g., CAT3)
- Ensuring the use of plenum-rated cable where required
- Improper terminations of cable on connectors
- Lack of cabling records

Cabling is part of the infrastructure that defines the physical layer (Layer 1).

Repeaters

Although some networks still use technology based on continuous waves (commonly called analog networks), most modern networks are digital, where the communications are sent via electrical signals or pulses of light. Digital signals tend to be much more resilient to errors than analog technologies, because electrical or light transmissions operate on a binary code basis (0 or 1) rather than having to account for what may be significant wave variation.

Digital signals suffer more strongly from attenuation (loss over distance) than analog traffic, because anything that becomes too weak to be detected is assumed to be a binary 0. However, this simplicity provides a correlating benefit: whereas analog attenuation tends to introduce noise that makes rejuvenation difficult, any detectable signal on a digital line can be boosted to full strength with confidence that it represents a binary 1. As a result, even the faintest digital signal can be rejuvenated without introducing errors, provided that this rejuvenation occurs before the signal becomes too weak to detect. These traits make digital networking both simpler and faster than analog networking.

Repeaters are used to extend the length of a signal being transmitted over cable or wireless networks. Repeaters placed at properly offset locations are able to receive an attenuated input signal, regenerate the signal to full strength, and send it on further. The distance between repeaters is based on the type of cabling or technology being used and the operational environment. For example, as the quality of fiber has increased over the years, it has meant that the distance between repeaters has grown substantially. In an environment with many concrete walls or other interference, or where a higher frequency wireless channel is being used, repeaters may be required more often.

One risk associated with repeaters is that separating them by too much distance may fail to provide a clean, error-free signal. Another risk is that a wireless repeater providing a strong signal into areas outside the

perimeter of the organization's facilities might be subjected to unauthorized access.

Repeaters operate at the physical layer (Layer 1).

Switches

Switches are used to connect devices together. There are switches that operate at OSI Layers 3, 4, and 7 to handle functions such as load balancing. However, their most common function is to provide dedicated pathways to endpoints based on MAC address association (an OSI Layer 2 function).

In addition to connecting devices, switches can also segment and divide networks by isolating the ability of traffic to flow between endpoints. With such configurations in place, the results are comparable to running distinct physical infrastructure.

Areas of concern associated with switches include:

- Physical protection
- Ensuring proper configuration
- Documentation
- Device failure
- Protocol attacks

Routers

The purpose of a router is to connect networks (rather than devices). Fundamentally, they forward incoming packets in the direction of the destination IP address that is in the packet header. The router knows where it might forward packets based on a table of values that it builds using specialized routing protocols from the TCP/IP suite, such as the Border Gateway Protocol (BGP); by updating these tables based on messages that it receives, the router learns how best to direct traffic toward its destination.

In many ways, a router is like a traffic circle (roundabout) used to handle traffic on roadways. Traffic enters the circle from any point and leaves following the road that is best aligned with the vehicle's ultimate destination. The road taken may not be a direct pathway, but it will move traffic toward the destination. Routers regularly receive updates from their peers to provide awareness of network conditions, and a router may direct traffic to different routes depending on traffic volumes and congestion.

Some network traffic has labels that indicate it has a priority, similar to the way that emergency vehicles are permitted to bypass other traffic. These labels indicate that the packets should be processed quickly and not be held back by other packets waiting to be processed. The delay in processing is called latency, which might severely affect the quality of some types of processing, such as voice-over IP (VoIP) telephone calls or video teleconferencing. Labeling of the traffic allows for provision of traffic management based on target quality of service (QoS) and class of service (CoS). QoS is usually used to provide a guaranteed bandwidth for traffic volumes, while CoS is used to grant priority to certain packets over others (e.g., voice packets over regular data packets). This also helps to prevent jitter, a variation in the arrival time of a packet.

In addition to sending traffic on its way, routers can also be configured to block certain kinds of traffic based on source address, protocol, or other characteristics present in the IP header. Routers are intended primarily to ensure that traffic moves toward its destination, so blocking traffic is a secondary role but may be part of a layered defense strategy to protect networks.

Areas of concern associated with a router include:

- Improper configuration
- Use of weak protocols (e.g., RIPv1)
- Software bugs

- Unpatched systems
- Physical security
- Unintentional support for IPv6 (e.g., Teredo tunneling capabilities turned on by default)

Routers operate at the network layer (OSI Layer 3).

Firewalls

The term "firewall" refers to a variety of technologies that operate at various layers of the TCP/IP protocol stack and have evolved significantly over the years. However, in all forms, a firewall is a system or combination of systems that exists to enforce a boundary between two or more networks, typically between a secure environment and an open environment such as the internet. Firewalls may be used to control both incoming and outgoing traffic. Basic types of firewalls are described in **figure 4.4**.

Figure 4.4—Firewall Types

First Generation	A packet-filtering router that examines individual packets and enforces rules based on addresses, protocols, and ports, without awareness of how any given packet relates to any others.
Second Generation	Operates at Layer 4 and keeps track of connections in a state table, which allows it to enforce rules based on packets in the context of the communication session; commonly known as a stateful-inspection firewall.
Third Generation	Operates at Layer 7 to examine the application-level protocol being used, such as Hypertext Transfer Protocol (HTTP). Sensitive to suspicious activity related to the content of the message, rather than being limited to the address information.
Next Generation	An enhancement to third generation firewalls that brings in the functionality to prevent intrusions by inspecting Secure Sockets Layer (SSL) or Secure Shell (SSH) connections through deep packet inspection.

Firewall configurations should be backed up regularly, reviewed to ensure that all rules are in the correct order and documented. Firewalls should also be tested on a scheduled basis, and any changes to the firewall configuration or rules should be subject to organizational change management processes. Additionally, the risk practitioner should verify that the staff members managing firewalls and other network devices are knowledgeable, trained and supervised, with firewall logs regularly reviewed to detect any suspicious activity. In some enterprises, review of firewall logs is outsourced to a security services company. In such cases, the risk practitioner should review and understand the terms of the contract governing this service.

Proxies

A proxy is a device that acts as an intermediary between two communicating parties by presenting itself to each side of the communication as if it were the host on the other end. This arrangement allows the proxy to filter and examine suspicious activity, protect internal resources and act if unacceptable activity occurs.

Proxies are typically established at network perimeters. In some cases, proxy capabilities may be built into next-generation firewalls or pure cloud subscription base service; however, many enterprises use dedicated servers or appliances for proxy functions.

Intrusion Systems

Firewalls and perimeter routers are secured with the intent of creating a fortified perimeter through which malicious traffic will not pass. Layered defense, sometimes called “defense-in-depth,” assumes that perimeters are insufficient to protect the network and places additional security inside for added assurance. Intrusion systems come in two forms: the intrusion detection system (IDS), which identifies potentially malicious traffic, and the intrusion prevention system (IPS), which combines an IDS detection capability with selective firewall features to block traffic identified as potentially malicious.

The basic rationale for using an IDS over an IPS is that not all traffic *suspected* of being malicious is *actually* malicious, and that it is preferable to alert someone to investigate rather than cut off what might be normal or legitimate communications. This goal means that the IDS need not process traffic as it passes through but instead can sample traffic for analysis as an observer. An IDS, therefore, has no effect on network throughput. In contrast, for an IPS to work, it must be placed in the line of traffic so that it can stop it should the need arise. This generally means that an IPS will slow down a network based on the limits of its processing power.

Both detection and prevention systems can be implemented at the network or host level. In the latter case, the IDS or IPS takes the form of a software application and can be set up to monitor activity in the general sense or specific targets of interest, such as attempts to change system files.

Machine learning (ML) has been used to enhance existing signature- and anomaly-based detection, further automating intrusion detection. Rules can be rewritten on the fly using ML-based and -enabled technologies.

The Domain Name System

Network addresses operate as sets of numeric values that exist in hierarchies. Requests to access distant endpoints are processed based on these addresses. However, most people do not know the addresses associated with particular endpoints or websites. In that sense, the Domain Name System (DNS) is the mechanism that makes the internet work. DNS provides a simple cross-reference that is used to associate a written name with the IP address used by network devices. An individual or organization registers the name for a website and provides some basic technical information, after which users who want to visit that site can type the name instead of the address—for instance, www.isaca.org instead of 104.16.215.248. Not only is it more convenient to remember the name than the address, but later changes to the address need not affect the ability to reach the website, so long as the mapping remains up to date.

DNS is structured as a logical tree. When a network device does not know the IP address associated with a particular name, it sends a DNS request up through the tree to a higher-level DNS resolver. At the top level are “root” DNS servers that can direct queries back down appropriate paths to servers that have the answer. The reply is then sent to the requesting device using UDP over port 53, after which the requesting device stores the IP address and name to reference for future use.

There have been many attacks on the internet using DNS over the years. Malicious users have sent false DNS replies to misroute traffic, and DNS replies have been used in amplification attacks to flood a victim’s system. Attacks against DNS servers that impede name resolution can cause considerable difficulty for e-commerce and other basic business transactions. DNS can also be used to learn information about a company that may be useful in planning attacks. Risk practitioners reviewing networks should take time to understand their enterprise’s specific approaches to DNS, and the security features that have been put in place to limit these and other DNS-related risk.

DNS is an application layer protocol (OSI Layer 7).

Wireless Access Points

Wireless devices offer a level of flexibility and ease of use not possible with traditional cable-based networks, allowing users to move around and log in from multiple locations without requiring network cables or ports. However, the lack of a defined physical boundary increases the threat of unauthorized users being able to access wireless-enabled networks.

Wireless infrastructure is typically established using one or more of the protocols associated with the 802.11 standard, with specific standards allowing for specific maximum transfer speeds, security protections, and other features. A good practice is to segment the wireless infrastructure into a network distinct from the wired infrastructure and implement strong password requirements for network access. WPA3-Enterprise and 802.11w protected management frames (PMFs) are often recommended by regulators.

Placement of wireless access points is also important. Risk practitioners reviewing wireless networks should ensure that access points are in locations not subject to interference from other devices. Access points operating on Wi-Fi 5 (802.11ac) or later are designed to moderate their power levels to avoid creating interference over distances and often deliver the best performance when located inside the rooms that they will support. Placing access points above the ceiling may result in signal degradation arising from HVAC and utility pipes.

Insertion of unauthorized (rogue) wireless access points on the network may permit a person to access the network directly without having to connect through a secure device or to bypass firewalls or other layers of defense. Detecting this type of vulnerability is generally possible only with a combination of diligence and technical expertise, particularly if the rogue access point has been installed by someone who has legitimate physical access to the organization's workspace. The risk practitioner should ensure that wireless discovery scans are part of the overall vulnerability assessment process, especially if wireless technology is not known to be used within the enterprise.

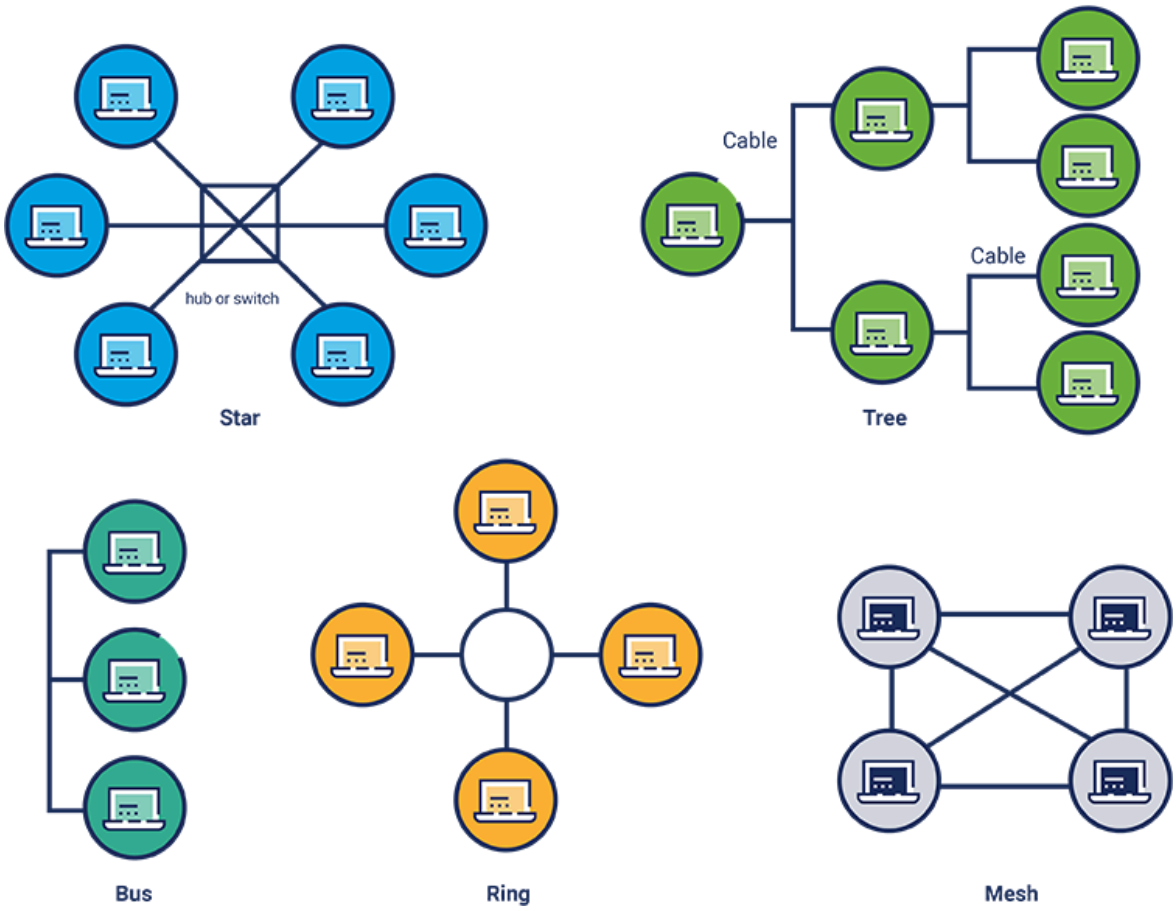
In addition to 802.11 network signaling, organizations may also have Bluetooth devices present in workspaces. Bluetooth was once standardized as IEEE 802.15.1 but is currently maintained by the Bluetooth Special Interest Group. Its purpose is to easily link devices physically close to one another into personal area networks (PANs). Some of the most common uses for Bluetooth are linking computers or mobile phones to peripherals such as keyboards, mice, and headsets. Several attacks against Bluetooth have been identified by researchers as viable; however, successful exploitation of these attacks is rare.

In addition to local network technologies, wide area wireless technologies, such as WiMAX (IEEE 802.16) and 5G cellular (ITU IMT-2020), are in use. Recent proliferation in low-Earth orbit (LEO) satellites is also changing the nature of wireless communications. For the risk practitioner, it may not be practical or even possible to isolate organizational endpoints within secure enclaves for much longer. The potential for devices connected to several networks simultaneously to be leveraged by malicious actors as pathways into enterprise environments is part of the calculation driving a migration away from strong perimeters toward assumptions of zero trust.

Network Topologies

The arrangement of endpoints on a network is known as a network topology. **Figure 4.5** illustrates the commonly used bus, ring, and star topologies.

Figure 4.5—Physical Topologies Commonly in Use



Source: ISACA, *CISA Official Review Manual, 28th Edition*, USA, 2024

A bus topology connects every device by means of one communications path. The design is simple and cost-effective, which is why it has been used for decades to carry cable television signals. The key vulnerability lies in upstream dependency: a cut cable results in failure for every user connected downstream of the cut. It is also relatively easy to intercept traffic on a bus network, a point of particular concern for some users of cable-based internet access.

In a star topology, every device is connected to a central switch, which is more efficient than a bus since there are shorter paths from any end point to the switch. The switch design also makes it more difficult for one user to intercept traffic intended for another. Star topologies are more vulnerable to interruption than bus topologies, because loss of the central switch affects all users. However, the switch can generally be more easily protected than a bus cable.

A series of star networks arranged with branches to other star networks is sometimes called a tree topology. Tree networks are popular because they scale well: a cut link between the branches of the tree causes isolation of that branch but does not otherwise impede the network.

A ring topology is used in backbones and areas where reliable high-speed communications and fault tolerance is desired. A ring connects every device and allows traffic to pass in one or both directions; if the ring is bidirectional, a single cut does not affect the network at all. Ring topologies are excellent for busy networks where switching would introduce too much delay due to processing overhead. They are also considerably more expensive than bus, star or tree topologies.

Where the highest availability is required, a mesh topology is the answer. In a mesh, many devices are connected to many other devices so that traffic can route around a failure in any part of the network. The internet itself is a partial mesh and was built to survive massive failures of any one part of the network, while still allowing communications over the rest. Mesh networks are very costly, and they do not scale

well with physical lines due to the need to connect each device to many other devices. Wireless links make locally oriented mesh architectures considerably easier to architect and maintain.

Network Types

Certain elements of network architecture depend on how a network is intended to be used. There are two principal types of networks: local and wide area. While these terms convey impressions of geographic distance, what actually defines something as “local” or “wide” is the degree of logical network separation between destinations, requiring the use of different methods and protocols from the TCP/IP suite for optimum performance.

Local Area Networks

A LAN is a network that serves several users within a specified nearby geographic area, such as a building, floor, or neighborhood. LANs often use star or tree topologies, although wireless LANs may be meshed.

Although LANs vary regarding both user count and services provided, the common trait of every LAN is that its endpoints are logically close together.[41] Within that basic definition, numerous types of networks can arise. LANs intended purely for personal use within homes or around individuals are sometimes called PANs, while a LAN built for the express purpose of connecting storage devices to servers and other computing devices might be called a storage area network (SAN). Despite the variations in these use cases, both are LANs for practical purposes, because traffic within these environments is within an “autonomous system” under the control of a single enterprise.

The logical proximity of traffic within a LAN favors the use of interior gateway protocols (IGPs) from the TCP/IP suite, which are relatively simple. IGPs include:

- Routing Information Protocol (RIP)
- Open Shortest Path First (OSPF)
- Intermediate System to Intermediate System (IS-IS)
- Enhanced Interior Gateway Routing Protocol (EIGRP)

Wide Area Networks

When endpoints are logically distant from one another, operating on separate routing blocks, the solution is to interconnect them using a wide area network (WAN). The remote locations connected by WANs may be physically short distances such as between floors or cover extremely long transmission ranges between regions or continents. Some sources refer to WANs that extend only over limited areas such as cities as metropolitan area networks (MANs). However, their practical traits remain the same: they carry traffic destined to cross network borders.

The logical distance of traffic in a WAN benefits from the use of exterior gateway protocols (EGPs) from the TCP/IP suite, which are more complex than IGPs. Several EGPs exist, but the most widely used is the Border Gateway Protocol (BGP).

Software-defined Networking

Enterprise networks at both the local and wide area levels are increasingly defined in software that separates network control and forwarding functions. This software-defined networking (SDN) allows dynamic shaping of traffic, so networks can be changed dynamically to meet business requirements on short notice. For instance, wireless access points might be modified to switch between 2.4GHz and 5GHz based on network conditions, while an SD-WAN can manage connections across broadband, mobile, and traditional circuits simultaneously. Virtualization of customer-premise equipment reduces costs associated with establishing or closing workspaces, allowing greater business agility than has traditionally been the case.

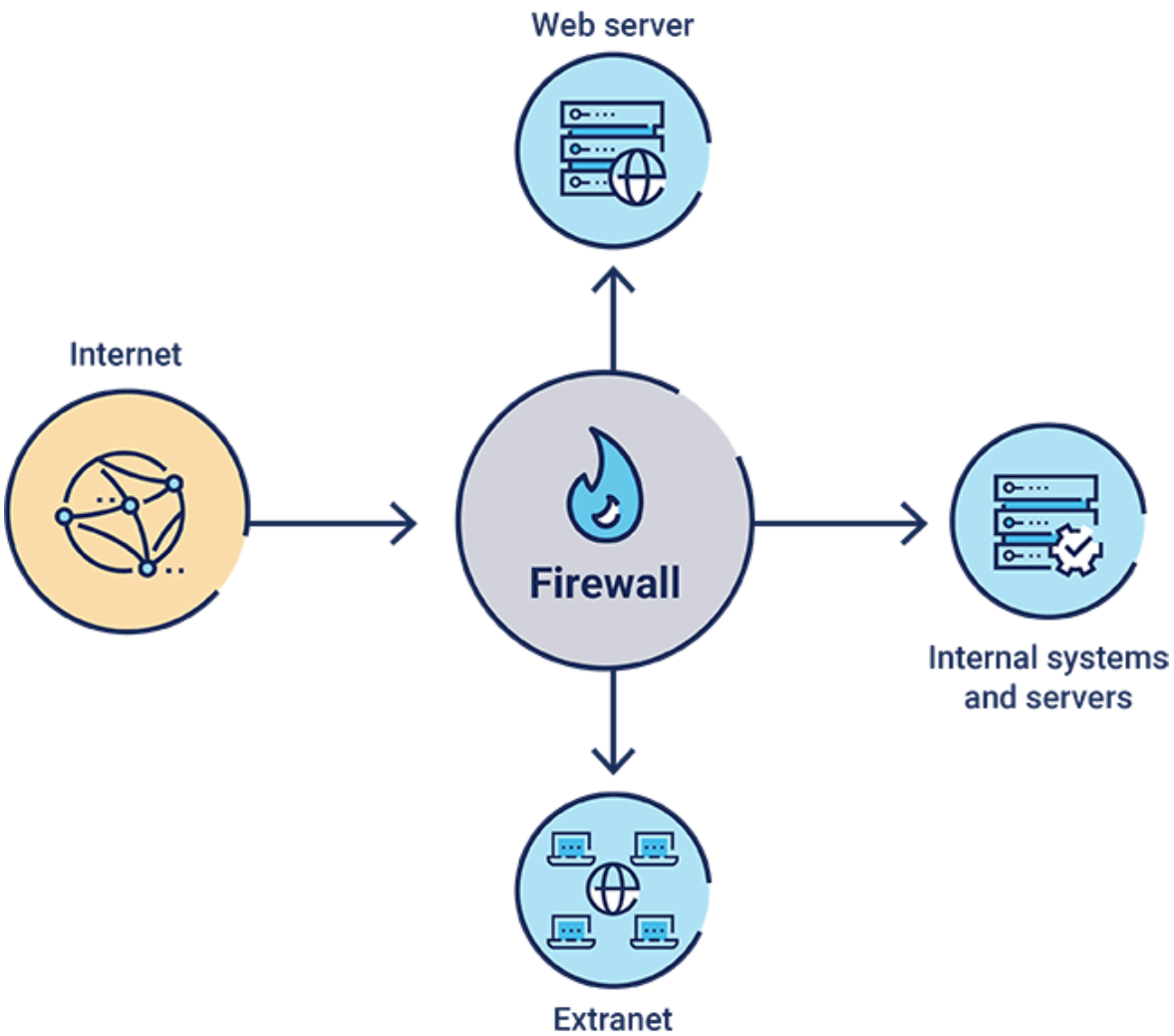
SD-WAN functionality is increasingly augmented with security functions such as a secure web gateway (SWG), cloud access security broker (CASB), firewall as a service (FWaaS) and zero-trust network access (ZTNA). Vendors package these combination offerings under the umbrella of secure access service edge (SASE), and enterprises use them to facilitate secure network access from distributed trusted environments such as securing increasing numbers of staff working from home.

Demilitarized Zones

Network borders exist to prevent outsiders from directly accessing systems within particular LANs. Some services are intended for outside use, and these are typically placed in network segments off of the border, expressly configured to allow open access. All devices in this demilitarized zone (DMZ) are hardened with unnecessary functionality disabled. IDSs or IPSs are generally placed to monitor, record, and potentially block suspicious activity. Firewalls in the DMZ are generally placed behind packet-filtering routers that clear out obvious bad traffic in advance.

As seen in **figure 4.6**, the firewall ensures that traffic from the outside is routed into the DMZ where the web server is located. Critical organizational assets are not placed within the DMZ because it is subject to attack and compromise from the outside. External users cannot access the internal network directly, thus providing the internal network with some measure of protection.

Figure 4.6—The Demilitarized Zone



Virtual Private Networks

Under ordinary conditions, it is easy to capture WAN traffic passing over the internet or by way of directional connections. Virtual private networks (VPNs) were designed to make this much more difficult. A VPN uses existing telecommunications infrastructure without regard to its inherent security. However, the data signal is logically separated from other traffic by digitally constructed tunnels, which are then configured using encryption (see section 4.8 Security Concepts, Frameworks, and Standards) to make the traffic unreadable except by intended recipients. Once established, a VPN functions in a manner similar to a point-to-point leased line but at a considerably lower cost.

Current computing architectures can support many VPN connections simultaneously, allowing a substantial portion of the organization's workforce to connect to corporate infrastructure from remote locations—potentially anywhere in the world where the internet can be accessed, whether by wired or wireless infrastructure. Once connected, VPN participants are logically close to one another and operate as part of the same LAN. VPNs may be established using several different technologies, including the internet layer using the security extensions to the Internet Protocol (IPSec) or the transport layer using Transport Layer Security (TLS).[42] In general, an IPSec VPN is more commonly used for bulk channel encryption between networks, while a TLS VPN is more likely to exist between network endpoints.

Zero Trust Architecture

Zero trust and zero-trust architecture are based on moving the focus of cybersecurity defenses, primarily the authentication, authorization, and use of various IT resources from network-based perimeters to the users and assets regardless of their logical or physical locations or any implicit ownership of assigned assets. NIST SP 800-207 provides the following explanation for zero trust:

> *Zero trust (ZT) is the term for an evolving set of cybersecurity paradigms that move defenses from static, network-based perimeters to focus on users, assets, and resources. A zero-trust architecture (ZTA) uses zero trust principles to plan industrial and enterprise infrastructure and workflows. Zero trust focuses on protecting resources (assets, services, workflows, network accounts, etc.), not network segments, as the network location is no longer seen as the prime component to the security posture of the resource.*[43]

Zero-trust strategy is a critical component of building modern network services that provide secure access to authorized internal systems and private cloud-based environments for end users physically located anywhere in the world. The shift toward digital transformation that began in 2020 accelerated the adoption of distributed work environments and work-from-home policies for many enterprises globally. The added complexity of distributed work environments, where nothing is trusted implicitly, requires real-time monitoring and the granular visibility of user and application behavior attributes. These attributes are extensive and comprised of hundreds of items such as:

- User identity (human or programmatic)
- Privileged user identity
- Credential type (password, hardware token, API key/secret)
- User behavior baseline (normal user application/network behavior)
- System behavior baseline (normal device behavior)
- Asset inventory of endpoint devices
- Hardware geolocation
- Hardware, firmware, and software versions
- OS version and patch level
- Installed software inventory per endpoint
- Insecure protocol usage and detection (unencrypted communications such as HTTP, File Transfer Protocol [FTP], and Telnet)
- EDR logs, including malicious or suspicious system or user activity

Without the ability to monitor these attributes or programmatically correlate data with threat intelligence sources and other organizational telemetry through ML data training, it is not possible to strategically deploy a functioning and comprehensive zero-trust architecture.

Insider threats will commonly skip most tactics related to achieving initial access and evading detection. This threat actor will use whatever privileges and access they have from the enterprise to carry out their goals. Common tactics include abusing IT resources for personal gain, sensitive data exfiltration, data/system destruction, or service disruption.

4.2.5 Technology Refresh

Many organizations use outdated technologies that are difficult to obtain, support, and maintain. Technology in use may have been acquired through multiple projects and/or mergers and consist of products from a mix of vendors, in different languages and with distinct configurations, running on different OSs, hardware, and databases. A large organization might have systems based on mainframes, client-servers, virtual environments, and the cloud all at once. The complexity of such environments creates uncertainty and risk.

It is good practice to have a simple, easily managed and controlled environment with standard products and technologies, but this may be nearly impossible to attain in a large organization. In general, enterprises that retain legacy systems do so because there is a compelling business need. Many systems may continue to be used long after their anticipated life span simply because it is not cost-effective to replace them, especially in organizations carrying out manufacturing or industrial activities in which computers are specially integrated to control physical machinery.

Considerations that affect risk assessment related to technology include:

- Age of equipment
- Expertise available for maintenance
- Variety of vendors/suppliers (are they still in business?)
- Documentation of systems
- Availability of replacement parts
- Ability to test systems or equipment
- Operating environment and user expertise
- Ability to patch/mitigate vulnerabilities
- Organizational willingness to accept change
- Supply chain/vendor lock-in

The risk practitioner should work with business process owners and technical staff to determine what legacy systems are in use. It is also important to verify both that their continued use represents a compelling business need and that the risk associated with such use has been documented and accepted by senior management. In many cases, legacy systems persist out of need, but managers are unaware of the extent to which the organization incurs risk from their persistence. Under such circumstances, the role of the risk practitioner is to advise the risk owner of ways in which the assessed risk might be addressed in order to bring it into alignment with the organizational risk appetite (or at least to tolerable levels). Compensating controls are very often necessary when dealing with legacy systems that retain critical status within an enterprise.

4.2.6 IT Operations and Management Evaluation

Staff members responsible for IT operations are frequently the first to be aware of problems relating to systems and applications. Interviewing operations staff and reviewing logs and trouble tickets can help the risk practitioner gain insight into unmitigated or recurring problems within a system, which should be investigated to determine whether they pose unaccepted risk to the enterprise. Once identified, these areas

of risk should be analyzed and addressed appropriately, whether that means formalizing their acceptance or taking other actions to bring them within acceptable or tolerable levels.

IT operations typically include multiple functions related to risk management and quality assurance, including policies and procedures for the management of incidents, configurations, problems, and releases of new systems or software. The risk practitioner should work with IT staff to understand these functions and how they are carried out. Weaknesses in any of the IT functions may create opportunities for threat agents to exploit systems or processes.

Many elements of IT risk are a result of how an IT department is run and managed. Where an attitude of complacency reigns, risk ignorance can result in breaches of security. Security problems commonly seen within the IT department include sharing high-level accounts and passwords and the lack of control over changes to production systems. The pressure to complete projects on time or meet demands from the business can result in shortcuts that pose significant unaccepted risk to the business.

Configuration Management

Devices and systems must typically be configured after installation to support communications, interfaces with other organizational systems and secure operations directed by policy. The goal of configuration management is to have a single approved way in which systems or devices intended for a particular role should be configured for use. Use of a common configuration makes it easier to deploy new systems, test patches and upgrades, identify the presence of malware, and manage the enterprise.

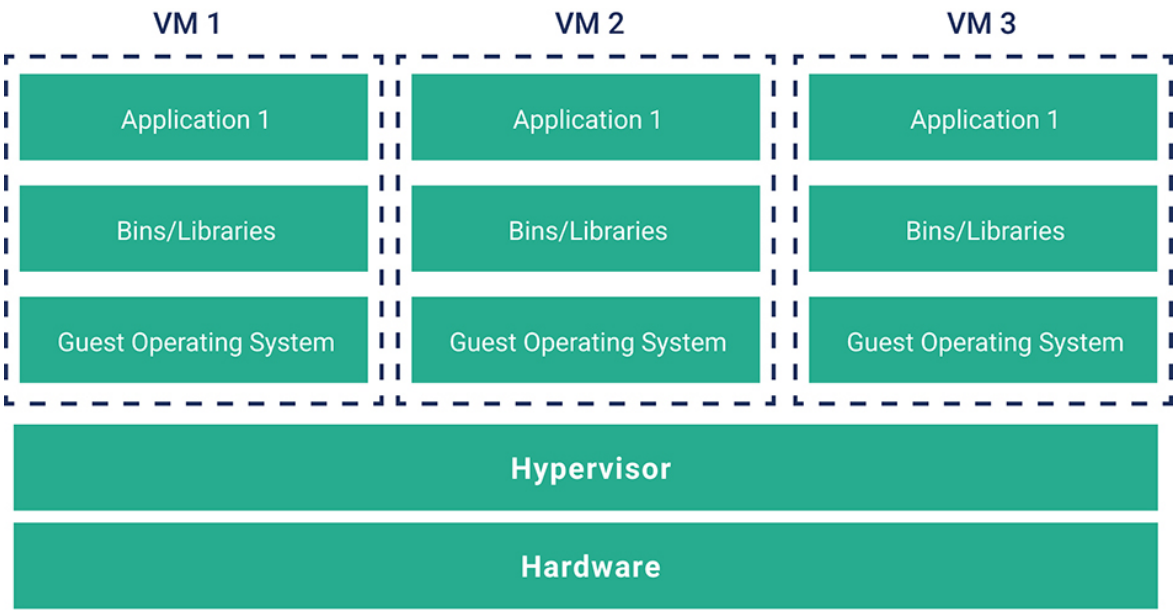
Configuration management often includes hardening, a process that reduces vulnerability by limiting the attack vectors that might be used as points of compromise. A hardened system is one that does not store sensitive data except when immediately needed to support a business operation. In addition, it has all unnecessary functionality disabled, including ports, services, and protocols that are not required for the intended use of the system within the enterprise environment. Many devices and systems come with guest accounts or default passwords that should be changed or disabled as part of the hardening process. While hardening is a good practice, the risk practitioner should understand that it can be difficult to identify necessary services and functionality. Hardening systems based on third-party guidance should be done with great care to prevent impacts to operations. Many custom-integrated systems cannot be hardened without significant negative effects.

Configurations and settings that control the operation of devices should be backed up and available in case of equipment failure. The risk practitioner should ensure that there are policies and procedures in place that apply to proper configuration management and that backups of standard configurations are available for use in recovery scenarios.

4.2.7 Virtualization and Cloud Computing

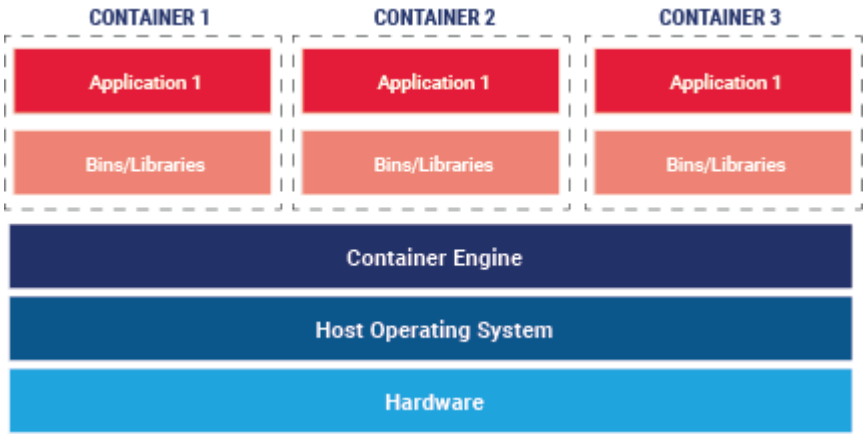
While most personal computers run their OSs directly on hardware, enterprise computing has shifted over the last two decades in favor of establishing production OSs in virtual environments abstracted from hardware by an intermediate host layer. These virtualized environments interact with physical hardware resources through the host layer without awareness of or ability to manipulate it, making it possible to maximize the potential of hardware by making it available to multiple OSs. In some cases, each virtual environment contains a full operating system and associated applications, which is collectively called a virtual machine (VM) (**figure** 4.7). It is also possible to allow a single OS to interact with distinct sets of libraries and files with their own applications, in which case, each set is called a container (**figure** 4.8).

Figure 4.7—Diagram of Virtual Machines



Source: ISACA, *CCOA Official Review Manual*, USA, 2025

Figure 4.8—Diagram of Containerization



Source: ISACA, *CISA Official Review Manual, 28th Edition*, USA, 2024

Containers present a lighter footprint and tend to operate more quickly, while VMs offer enhanced security because each OS is independent. However, containers share the same OS kernel, which may increase the risk of container escape or lateral movement if not properly isolated. Both types of virtualization dramatically enhance continuity and recovery by making it possible to move a running environment to alternate compatible hardware without a logical interruption in processing. They also dramatically reduce the need for physical space, since the same number of servers can be established virtually on a smaller number of physical platforms. The advent of technologies such as SDN and very low prices for high-bandwidth connectivity has further supercharged the enterprise shift toward virtualization with the ability to provision hardware capacity on demand.

Global technology companies such as Amazon, Microsoft, and Google host enormous data center environments in which VMs and containers can be provisioned against readily available hardware whenever and for however long they are needed. Equipped with state-of-the-art redundancy for power, connectivity and other risk factors, these data centers make it possible for enterprises to operate without *any* physical infrastructure beyond the connectivity needed to access provisioned capacity via remote desktop interfaces. Without having to worry about the physical elements of where or how these systems were supported, enterprises can realize substantial near-term cost savings while gaining access to capacity

and protective measures that represent the best in the industry. What actually occurs within these internet-connected data centers is generally opaque to client enterprises, similar to the use of a cloud in network diagrams to refer to the internet; hence, the term "cloud computing" or moving operations "to the cloud."

Hyperconverged infrastructure (HCI), a software-defined system for unified data center operations that combines storage, processing, networking, and management functions now makes workload location agnostic, similar to the way that public utilities operate. Through simplified management and reduced complexity, organizations can better focus on delivering information services rather than technologies.

While cloud computing has many advantages, it does create risk. Cloud data centers are exceptionally protected but also exceptionally tempting targets because of the sheer volume of data that consolidation brings together. The specific security practices of a given cloud provider may not be known to an enterprise contracting with them; typically, the provider shares only a standardized report from a third-party auditor assessing compliance with certain standards. Enterprises should also take care to understand where their data may be physically stored, since this can determine jurisdiction for purposes of privacy law and regulation (see section 4.10 Data Privacy and Data Protection Principles). From the perspective of the risk practitioner, moving operations to the cloud is a form of risk transfer, and an enterprise is never fully absolved of responsibility for risk to its own data, operations, and reputation when risk is transferred (see Chapter 3 Risk Response and Reporting).

Should organizational data be compromised, or systems fail in cloud environments, the enterprise will experience the bulk of the impact, regardless of what offsets may be afforded by service level agreements (SLAs) or contractual terms.

These considerations may not alter the decision to migrate to or maintain operations in the cloud. Such decisions are made for business reasons, and risk management serves the interests of the business. The role of the risk practitioner is to ensure that cloud-related risk is included in the discussion and accepted by management.

See section 2.3.1 Sources of Vulnerabilities for more information on cloud computing vulnerabilities.

4.3 System Development Life Cycle

Key Takeaways

- A system that is successfully developed may nonetheless not yield anticipated benefits for the enterprise.
- A structured approach to system development helps create and maintain systems that deliver anticipated business value.
- Security should be considered early in the life cycle, when it is easiest and cheapest to incorporate controls into the design.

Systems exist in all organizations, and it is common for specialized requirements to result in customization, including application software and integrated platforms for particular business use. Complex systems can deliver business value, but they also can be sources of significant risk. Effective management of systemic risk is best accomplished through a rigorous and comprehensive project-based approach to system development, commonly called a system development life cycle (SDLC).

Although specific development methodologies may use unique terminology or variations in ordering, there are certain traits and activities common to most SDLC structures in use today as a result of their common purpose. One example of an SDLC is seen in **figure 4.9**.

Figure 4.9—Characteristics of the SDLC Phases

SDLC Phase	Phase Characteristics	Support From Risk Management Activities
Phase 1—Initiation	The need for an IT system is expressed and endorsed by a sponsor, and the purpose and scope of the anticipated IT system is documented.	Identified risk existing within business processes or activities of the proposed system is used to develop system requirements, including security requirements and a security concept of operations (strategy).
Phase 2—Development or Acquisition	The IT system is designed, purchased, programmed, developed, or otherwise constructed. This may be done within or outside the organization.	Risk identified during this phase supports security analyses of the IT system that may lead to architecture and design trade-offs during system development.
Phase 3—Implementation	The system security features are configured, enabled, tested, and verified.	The risk management process supports implementation against requirements and within its modeled operational environment. Decisions regarding identified risk are made and documented prior to system operation. In many environments, this process culminates in a formal authorization of the system for production use.
Phase 4—Operation or Maintenance	The system performs its functions, perhaps undergoing periodic updates or changes to hardware and software or is otherwise altered to better align with changes to organizational processes, policies, and procedures.	Risk management activities focus on maintaining acceptable levels of risk as established by the earlier authorization decision. Organizations may use periodic reassessment or a continuous monitoring methodology as a means of accomplishing this maintenance of risk alignment.
Phase 5—Disposal	The system is formally removed from production use, which may include disposition or reallocation of information, hardware and software. Depending on the business case for disposal, this	Risk management in this phase focuses on ensuring that system migration is conducted in a secure and systematic manner, hardware and software are properly disposed of, and

SDLC Phase	Phase Characteristics	Support From Risk Management Activities
	phase may be triggered by migration to a replacement system or discontinuation of the processes driven or supported by the system.	residual data is handled appropriately.

Source: ISACA, *CISM Review Manual, 16th Edition*, USA, 2022

The SDLC is fundamentally a methodology intended to support effective project management. There are numerous approaches to managing projects; however, many core principles are the same. Proper oversight, clear requirements, user involvement, communications between team members and users, and regular review of project progress are all critical to project success under both waterfall and Agile styles of project management. The risk practitioner will often find projects at risk of failure and should be able to identify the causes of these looming failures, recommend solutions and report the risk to management.

System development projects fail for many reasons, including:

- Changes in requirements arising from new business priorities, incomplete understanding of initial goals or poorly managed additions (scope creep)
- Nonavailability of resources, which may be trained staff, budget, technology, or something else on which success is dependent
- Delays in delivery of outsourced components
- Results of developed or outsourced technology that misalign with what was expected
- Excessive complexity that exceeds the capacity of management or monitoring
- Lack of leadership, accountability or oversight
- Unrecognized symptoms of failure
- Lack of coordination with suppliers

The risk practitioner should verify that project design, development, and testing do not solely focus on the business functions of the project. Security is a necessity in all modern business processes, and it is considerably easier and less expensive to address security requirements by building them into the project timeline at the onset than attempting to add them into the project later. Security requirements should be specified, validated, and tested for utility in the same manner as other requirements to show that they reduce the risk associated with confidentiality, integrity, and availability (CIA). The risk management process should be incorporated into each step of the SDLC, with security requirements integrated into the project life cycle.

Key security tasks to perform during the SDLC to expressly document the risk associated with the development of a new program include:

- **Security categorization of the proposed system**—What are its CIA requirements?
- What impact would an outage have on critical business processes (i.e., business impact analysis)?
- **Privacy impact assessment**—What sensitive data is processed, stored, or transmitted by this system? What laws or regulations apply?
- **Vendor/supplier security or risk assessment**—Are key processes reliable and secure?
- Is there security training for all development staff and a secure environment? Are secure coding practices mandated and enforced?
- What is the level of awareness of inherent vulnerabilities present in or associated with the selected technology or operational environments?

The ability to audit and review applications or systems after implementation is an important part of the SDLC. Maintenance is inevitable and prone to changing assumptions and features associated with a complex system. Assessment and auditing of changes and operating status are necessary to ensure ongoing proper operation of the system.

As the system moves through the phases of the SDLC, new risk may emerge and previous risk assessments may need to be revised. This requires the risk practitioner to work with the project team to identify and determine optimal responses to risk, something that is especially important when changes are proposed to an existing application. Risk practitioners should be alert to whether the development team is following enterprise standards and policies for secure system development and the implementation of controls. Failure to adhere to these requirements may represent a risk to the enterprise and should be escalated to management for resolution wherever identified.

Additionally, the risk practitioner should be aware of the distinction between project risk, which deals with the consequences of failing to deliver the promised results on time and within budget and the risk that the deliverables may not meet the needs of the organization. The SDLC presented here generally reflects a waterfall methodology in which requirements are finalized before development begins. In situations that have substantial delays between the preparation of detailed requirements and shipment of final deliverables, there is substantial risk that changing circumstances will make what is delivered irrelevant, even if all deliverables are met. Agile development methods based on regular releases of minimum viable products and regular engagement with stakeholders for feedback on deliverables in progress can help ensure that projects focus on delivering what the organization needs.

4.4 Data Life Cycle Management

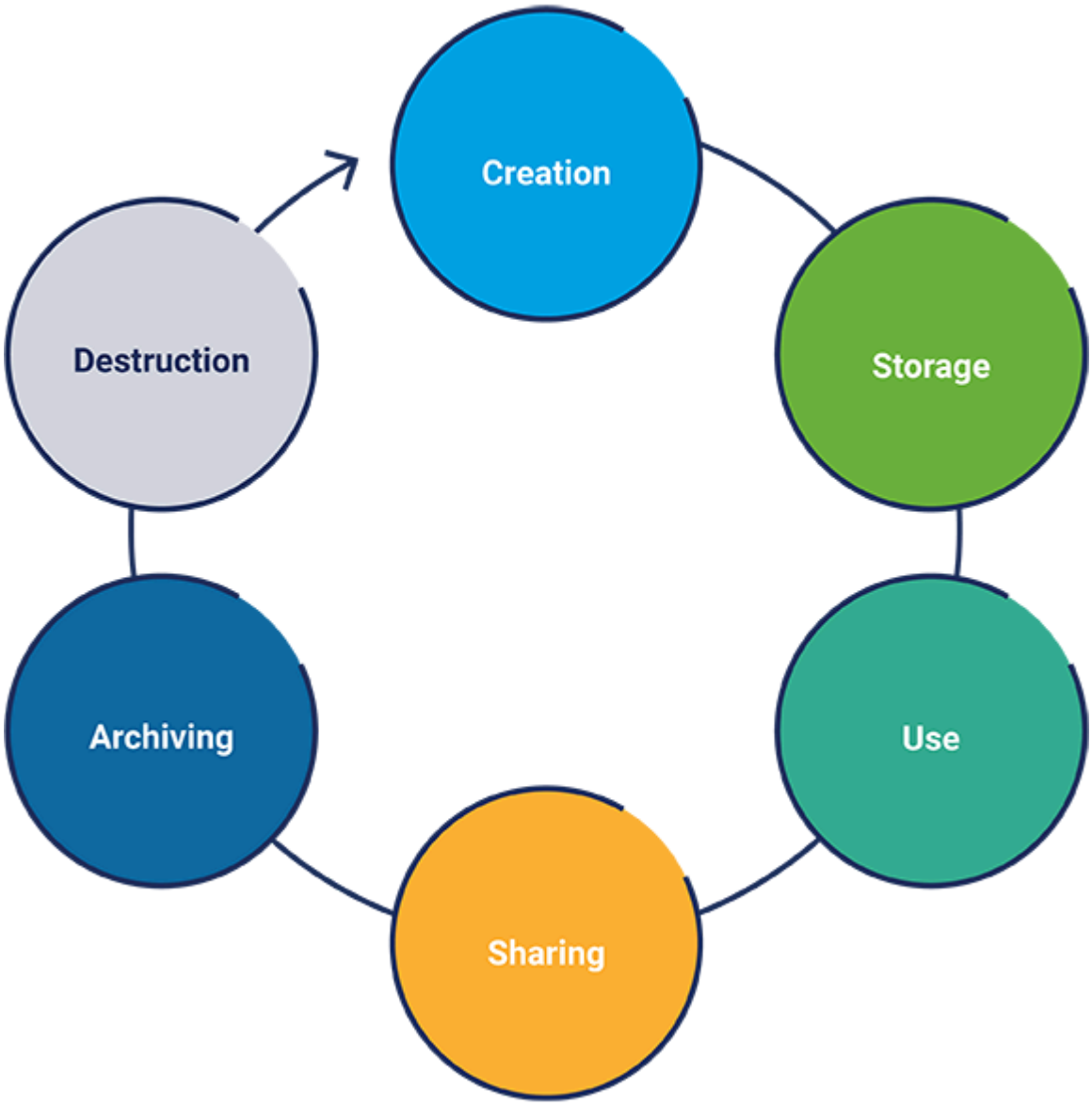
Key Takeaways

- Data moves within and across enterprises for several reasons, which vary based on the needs of each enterprise.
- The volume of data today makes protecting all of it infeasible, so proper data protection depends on identification and classification based on value.
- Specialized technologies exist to manage the risk of data loss.

Data is commonly viewed as following a six-phase life cycle. Initially, data is created. It is then stored and thus becomes available for use, which is its third phase. In modern enterprises, data use frequently involves sharing, regarded as a fourth phase in a cyclical approach. When data is no longer needed for regular use, it is archived, and if its lack of use extends long enough, it may be destroyed.

In practice, this life cycle contains many caveats. Creation may refer to original collection, but it may also be a product of synthesis from other data. In this way, the creation of data may result directly from sharing. Conversely, even in modern enterprises, not all data is shared. The archiving of data is a good practice, but it might be mandated by law, regulation or contract. On the other hand, law, regulation or contract might also prohibit archiving of data beyond strict necessity, and instead require that it be verifiably destroyed by a certain date. The data management life cycle, shown in **figure 4.10,** should be understood as a reference model subject to interpretation within specific enterprises, rather than a standard of practice that can be universally applied.

Figure 4.10—The Data Management Life Cycle



Throughout the data management life cycle, numerous areas of risk can arise. One is a lack of clear ownership of data, which makes it harder to verify what requirements apply to the data and obtain approval to take steps such as archiving, sharing or destruction. The risk practitioner should review and assess the data ownership and management process of the organization, including the protection of data from improper disclosure, modification, or deletion. Additionally, all staff who work with data in any form should be aware of the risk associated with improper data management (such as data leakage) and their obligation to comply with the policies and standards of the organization. These rules should be maintained and enforced.

IT management plays an active role in mitigating risk and supporting risk management activities. Above all, IT managers must abide by their own rules; this is crucial to developing a positive risk culture and promoting the integration of risk management principles into IT systems and projects. The risk practitioner should be observant of daily practices in the IT department and bring undocumented risk to the attention of accountable managers.

4.4.1 Data Management

Enterprises commonly regard data as being among their most valuable assets; however, attempting to protect all data in modern enterprises may create unsustainable cost or unacceptable risk. The goal of

effective data management is to ensure that data is protected appropriately for its value. This applies at all times and in all locations, including at rest, in transit, during processing, and when displayed, and to all formats, which include:

- Paper printouts and notes (e.g., reports, scratch pads)
- Magnetic media (e.g., hard drives, USB storage)
- Optical drive media
- Audio and video broadcasts
- Photos and screensavers
- Discarded material, especially anything intended for recycling

Because protection is value driven, determining appropriate protections for data requires first identifying data in terms of its use and then classifying it based on its value, which is derived from the importance of the business processes that use it. Protection of data therefore starts with reception. At the point that data is collected, the purpose and the intent of collection tend to be clearly understood and this is the opportune time to classify data on that basis. All data should be subject to validation checks before acceptance or processing to ensure appropriate formatting. In digital data collection, this includes ensuring that collected data strings do not contain embedded commands or other content that might adversely affect automated processing systems, such as Structured Query Language (SQL) code. A rigorous process of data validation includes:

- Range checks (e.g., allowable data values)
- Format checks (e.g., configuration of data)
- Special character checks (e.g., no script commands)
- Size checks (e.g., data aligns with expectations for type and purpose)
- Likelihood (e.g., entries correct in form but statistically unlikely, suggesting an error)

Data validation may be done either with an allowlist or denylist for data. An allowlist is the preferred approach in environments in which input data validation is based on static or infrequently changing values, where it is easier to anticipate what values would be reasonable than to anticipate what values might be malicious. The use of a common library for allowlisting can ensure that data validation occurs in a consistent manner across multiple applications.

Denylists are useful in environments in which the range of valid values is extremely broad, but in which only a few known values should be prohibited (such as an inappropriate word search) and these are either entirely static or are updated rarely.

Risk practitioners should be aware that there are often several different ways to present information that will ultimately be processed the same way; for instance, the ISACA website might be presented as http://www.isaca.org or https://isaca.org, both of which will be resolved to the same IP address through DNS and redirected transparently to the user. This phenomenon, called “canonicalization,” makes denylists harder to use in practice than might be expected, resulting in gaps that can be exploited by malicious actors.

Data protection also requires assurances that changes made will not affect the integrity, precision or accuracy of the data or of data processing operations. Mechanisms that may assist in meeting this requirement include:

- Data checks and balances of input compared to output
- Checks of normal compared to abnormal levels of processing
- Anti-malware detection software
- SoD defined at all necessary levels of a system or application
- Processes requiring approval for transactions (all or based on thresholds)

One of the most important elements of data protection is control over the permissions and authorization levels of users that can access data and applications. The risk practitioner should be sure that users are

granted the fewest permissions that they need to perform their job functions and that these privileges are granted only for the time periods in which they are necessary. This approach to permissions management is known as “least privilege.” Maintaining a least-privilege environment requires regular review of user access permissions and the revocation of permissions whenever a user leaves the enterprise or changes job roles. It is key to protecting data from improper alteration or disclosure.

Data commonly moves between networks and systems to serve multiple purposes within organizations. While in transit, data may be vulnerable to interception and unapproved removal (exfiltration). Enterprises can limit the risk of data transfer by sending data between network endpoints using encryption such as Transport Layer Security (TLS), which appears as an https: prefix in web addresses. The https: prefix is also used by the earlier Secure Socket Layer (SSL), which is no longer considered secure; however, many IT professionals continue to refer to TLS as SSL, introducing the potential for confusion. Additionally, versions of TLS prior to 1.2 have been found to have weaknesses. The risk practitioner should first confirm that there are no legitimate use cases in the enterprise for use of true SSL or TLS 1.1 or earlier. Once that is established, support for these earlier protocols can be disabled in browsers to promote data security in transit.

Data should also be protected while at rest, which includes keeping sensitive data in separate networks or on systems that are not accessible to unauthorized personnel (isolation) through some combination of role-based and physical access controls. Effective data isolation for sensitive data may include network segmentation through the use of firewalls, virtual local area networks (VLANs), or other technologies that serve to limit access. Encryption at both the volume and file levels is also commonly available in modern information systems and should be used where practical. At a minimum, portable or removable devices should be configured with whole-disk encryption to limit the potential for data loss associated with loss or theft of physical media. Risk practitioners in enterprises with customer-facing operations or data-use agreements should also keep in mind that external data owners may impose their own requirements for storing and protecting data, such as prohibiting the use of removable media or mandating particular methods for encryption at rest. Adhering to these requirements is part of safeguarding the enterprise against unaccepted risk.

4.4.2 Data Loss Prevention

In addition to the techniques and methods discussed in the prior section, organizations concerned about safeguarding data frequently implement specialized software for data loss prevention (DLP). Full-scope DLP solutions leverage data classification schemes (including ingress and egress points) to first determine what controls should apply to data and then apply policies to how data can be accessed, moved, shared or stored based on its classification. Violations may result in automated alerts, mandatory encryption or other automated protective actions meant to safeguard the organization and prevent data loss.

DLP generally monitors and controls endpoint activities and reviews dataflows within enterprise boundaries. In environments where compliance reporting is important, such as those involving law and regulation specific to certain types of data, implementing DLP can facilitate reporting obligations. DLP can also be valuable in determining when and how data moves as a means of mapping business processes and understanding key points in production processing.

While implementing DLP solutions, it is important to mitigate the risk of false negatives and false positives. A false negative in DLP occurs when sensitive data is mistakenly allowed to leave an organization, increasing the risk of data breaches or compliance violations. Whereas false positives occur when nonsensitive data is incorrectly flagged as potential data leak. This can lead to disrupted workflows, wasted time for cybersecurity teams, and potentially lowered confidence in the DLP system.

4.5 Portfolio and Project Management

Key Takeaways

- Projects are undertaken to accomplish specific objectives, while programs are ongoing activities that may include one or more projects.
- Portfolios are collections of projects and programs that share common traits.
- Many projects fail.
- Agile project management methodologies are more likely to deliver business value, while waterfall methodologies are more likely to predict and control cost.

A project is a series of tasks that work toward a common purpose with a defined end-state. Projects are undertaken in every enterprise and field of endeavor. The goal of a project is to deliver value by bringing about some specific set of conditions or outcomes. For this reason, a project must have an anticipated end. Activities that continue indefinitely are considered programs, which may encompass one or more projects in the course of pursuing their recurring or ongoing goals. Enterprises rely on projects and programs to execute the decisions of management and carry out their business functions.

Effective project management relies heavily on proper definition of a project at its inception and during the earliest stages of planning. Clearly defined objectives and requirements help to contain the scope of a project within boundaries that are aligned with agreed-upon resources. Clarity also greatly increases the likelihood that what a project delivers is closely aligned with what was originally requested. However, risk practitioners should keep in mind that it is not uncommon for requested features to prove less useful or important in practice than anticipated at the onset of planning.

Methodologies that emphasize regular customer evaluation of partially complete deliverables are more likely to identify these variances between real and anticipated need prior to finalization of deliverables, which can help manage risk. Agile methodologies such as Scrum, Kanban, and Extreme Programming (XP) are all examples of methodologies that incorporate this style of interim evaluation with the invitation to revise deliverables at each review, while the waterfall methodology is most commonly associated with the delivery of precisely what was originally requested. Because of their flexibility toward requirements, Agile methodologies are almost always better at delivering functionality of value to the user community. However, this flexibility makes controlling cost more complicated than under a Waterfall approach, where a precise understanding of what will be needed at the end makes it possible to predict associated costs from the onset. Which methodology is most appropriate for a given use case is likely to vary based on the nature of the project, customer expectations, organizational culture, and other factors.

Projects are often grouped with long-term programs into portfolios that share common characteristics. A single portfolio may include projects using different methodologies. The goal of portfolio management is to optimize business value and create a greater degree of oversight under one accountable authority who is also appropriately empowered to solve problems as they arise.

4.5.1 Project Risk

There is considerable risk associated with projects. Because projects have clear end-states, they also have the clear capacity to succeed or fail. Project failure is surprisingly common and may take the form of early cancellation, nondelivery of expected outcomes or lack of expected value relative to invested resources.

IT projects fail for various reasons, including:

- Unclear or changing requirements
- Addition of requirements without adequate resourcing (scope creep)

- Inadequate access to resources, including funding and specialized skill sets
- Problems with technology
- Delays in delivery of supporting elements/equipment
- Unrealistic timelines (push to market)
- Lack of progress reporting or effective communication

Project management is the formal discipline of organizing, administering, and carrying out projects. There are several distinct methodologies of project management, not all of which have a specific individual with the title or role of project manager (PM). However, even where there is no individual PM (as in self-directed methodologies such as Agile), the behavior of project teams is always intended to bring about the same effects as would arise from having a dedicated PM and lead to successful completion. Project management is, therefore, partially a form of risk management.

When a project is at risk, it is important to identify the root cause of the problem and take steps to address it as soon as possible. Lack of good project management can lead to:

- Loss of business or competitive advantage
- Low morale among staff members
- Inefficient processes
- Lack of testing of new systems or changes to existing systems
- Impact on other business operations
- Failure to meet contractual requirements
- Violations of law or regulations
- Insufficient QA activities

Projects are subject to numerous types of risk. Fortunately, project management methodology is well-developed, and many of the common types of risk also have common responses, such as:

- Implementing a change control board to prevent scope creep
- Prioritizing critical project tasks to use resources optimally
- Reorganizing or providing additional resources to overcome bottlenecks
- Replacing or supplementing project managers who fall short of expectations
- Canceling projects whose costs or schedules are far outside of projections or restarting them under more favorable conditions
- Replacing suppliers or renegotiating contracts that fail to deliver agreed-upon products or services

Timely identification of a project at risk of failure is important so that corrective action can be implemented while the situation is still salvageable. Identifying project risk is challenging in part because it can be difficult to obtain accurate data on project status and identify root causes of observed problems. Proper and engaged oversight and monitoring of the project along with validation of progress reports may reduce or even prevent inaccurate project status reporting. Objective risk assessments are often instrumental in determining true project status. It is a fundamental law of project management that time, quality, and cost exist in a balance. Calls to “do more with less” are workable only in environments where extreme levels of inefficiency or waste are both present and correctable, which is uncommon. Far more often, quality absorbs the impact. For instance, a project team that is struggling to remain on time and within budget while maintaining access to necessary resources may skip critical steps (such as testing) as a means of attempting to balance these priorities. Such actions create a temporary illusion of success but may lead to production failures, inaccurate reporting and data processing, or missing functionality as the project is implemented. The organizational impacts of cutting corners can include both direct and indirect financial losses, especially in terms of reputational impact that limits opportunities for future growth or revenue.

Projects are frequently assembled into programs. A program is a structured grouping of interdependent projects and steady-state operations that is both necessary and sufficient to achieve a desired business outcome and create some specified value. It is common for a program to rely on each project being

completed successfully on schedule. Accordingly, when a project is at risk, the entire program may also be at risk.

Risk practitioners who identify deficiencies in project planning or execution should bring these to management's attention through portfolio channels as soon as possible, because project trajectories become increasingly difficult to correct as they move further away from expectations. In particular, the risk practitioner should be aware of two specific concerns associated with project and program management: first, that a project may not meet its objectives, and second, that the failure of one or more projects may affect the performance of a program.

4.5.2 Project Closeout

Projects are distinguished from programs by their finite life span. A project may last months or years, but there must be an anticipated point at which deliverables are fully transitioned to users and/or system support staff and the project is closed.

Formal closeout procedures are an important part of managing risk. In particular, postimplementation or after-action reviews allow identification and capture of lessons learned that can be used to improve future projects. Stakeholder satisfaction should be considered as part of this process. However, projects are typically undertaken for the benefit of their sponsors. Accordingly, verifying sponsor satisfaction with outcomes is particularly vital.

Closeout procedures are often standardized within large enterprises. **Figure 4.11** lists five steps that are frequently addressed.

Figure 4.11—Project Closeout Steps

Step	Action
1	Assign responsibility for any outstanding issues to specific individuals and identify the related budget for addressing these issues (if applicable).
2	Assign custody of contracts and archive or transfer documentation to those who need it.
3	Conduct an initial postimplementation or after-action review with the project and development teams, users, and other stakeholders to identify lessons learned that can be applied to future projects. Topics to cover include: • Fulfillment of deliverable targets and any additional objectives • Attainment of project-related incentives • Adherence to the schedule and costs • Analyses of team dynamics and communication with outside stakeholders • System logs
4	Document in the risk register any risk identified in the course of the project, including risk that may be associated with proper use of the deliverables.
5	Complete a second postimplementation review after sufficient time has passed for the project deliverables to realize their full benefits and costs and use the results of this review to measure the project's overall success and impact on the business.

4.6 Technology Resilience and Disaster Response/Recovery

Key Takeaways

- The shift in operations to cloud providers has taken most recovery functions away from customer enterprises.
- Under many interruption scenarios, the only thing to be done is to wait for the cloud provider to recover services.
- Alternatives exist but can be cost-prohibitive.
- It is important that management understand this and accept the associated risk.

Until recently, the IT staff of medium and large enterprises spent considerable time on matters related to disaster recovery, a term that refers to the reestablishment of business and IT services following a disaster or incident within a predefined schedule and budget. Business continuity, discussed in Chapter 1 Governance, deals with organizational planning to continue vital functions in the event of disruption.

Because continuity operations cannot continue indefinitely, an effective plan for recovery and reconstitution has long been considered a crucial part of enterprise resiliency.

Large-scale migrations of processing and data storage to dynamically allocated, virtualized cloud environments and delivery of various functions as services has upended this traditional mindset. The largest technology providers are the cloud service providers for all others, and their plans must consider recovery in the classic sense. For their clients, the situation is very different: generally lacking hardware and other physical infrastructure of their own, cloud-reliant enterprises can generally do nothing to recover their operations until their hosts regain a level of operating capability sufficient to meet their expectations. This level varies from case to case, with enterprises that maintain their own virtual servers on dynamically allocated hardware able to plan for their own recovery as soon as host environments are ready, while those that use software as a service will be unable to resume production until the software returns to normal operations. The common thread, though, is that few enterprises can take immediate action in the case of a disruptive event and are instead obligated to wait for cloud providers to regain minimum functionality.

The risk posed by this is unclear. The vast majority of enterprises operating in the world today, from small businesses to multinational companies and government agencies, use and often rely on the services of just a few enormous cloud technology companies. These companies have built their data centers and networks for high availability, so major outages are relatively uncommon, but they do happen. When they do, operations at all enterprises reliant on those capabilities are negatively affected. Fortunately, all such outages so far have been resolved quickly. There is no data to predict the effects of an outage on a larger, more-lasting scale.

There are also few plausible strategies for risk mitigation. Returning to arrangements of owned infrastructure directly maintained by full-time staff is infeasible for many organizations today, many of which spent considerable time, money, and effort retooling operations for a cloud environment. Enterprises with the resources to afford it might opt for higher levels of resiliency offered by their chosen provider, such as replication to other regions, or even setting up a parallel environment with a competing cloud provider. The cost of this approach makes it unrealistic for most enterprises.

The most important role that the risk practitioner can plan as it relates to technology resilience is to ensure that the risk assumed by the enterprise through its particular combination of cloud technologies and services are well documented, fully understood, and formally accepted by management. Any risk that management deems to be within the risk appetite is acceptable. Problems arise when managers have an imperfect understanding of how much risk the enterprise is taking on, such as mistakenly believing that a SLA ensures particular levels of uptime rather than ensuring agreed-upon compensation for each instance in which the guaranteed level is not met. The use of cloud services is a form of risk transfer for which the enterprise retains the impact to its reputation in the event of loss. A credit in the next billing cycle may not be a sufficient offset for an outage that puts the enterprise at risk of collapse.

In cases where an enterprise maintains some level of on-premises or co-located physical infrastructure of its own, or where it performs its own system administration of virtual servers hosted in the cloud, traditional concepts such as backup rotations, snapshots, and recovery testing continue to make sense and should be carried out. The risk practitioner should be aware of the recovery objectives (e.g., recovery time objective, recovery point objective) set in the course of business continuity planning and verify that these are considered and met by the testing plans that enterprise IT staff have developed. In limited cases, it may also be considered worthwhile by management to have alternate means of providing a subset of services outside of the cloud environment. The extent to which these arrangements are reasonable is a business decision that the risk practitioner best informs by ensuring that management understands the current risk without such arrangements and how it compares to the stated risk appetite and risk tolerance.

4.7 Emerging Technologies

Key Takeaways

- Connectivity continues to get easier and cheaper, changing human behavior.
- Enormous amounts of data are created every day.
- Appliances and other previously simple devices are now forming networks.
- Voice and video can be convincingly falsified based on samples.
- Generative artificial intelligence can mimic human interactions but lacks human motivations and can create false information, accidentally or even intentionally.

New technologies continuously emerge on the modern market. Pressure to implement new technology is often influenced by inflated expectations of its utility and maturity and a focus on product functionality without attention paid to security. The desire to deploy new technologies for competitive advantage may cause the enterprise to lose sight of the business risk involved unless the risk practitioner is diligent and makes a compelling case for robust testing and assessment. One way to accomplish this is to use forecasting practices and techniques that have a longer-term outlook.

Emerging technologies often provide indicators years in advance of their potential. It is the job of the risk practitioner to consider the potential risk and controls for the application of these technologies that may present value to the enterprise. A well-managed change control process ensures that new technologies are not implemented until the security team has been able to validate the security impact of the change and enable appropriate controls. However, if the IT department is unwilling to review and integrate new technologies, it is possible that the business will find ways to implement them regardless, putting the organization in a vulnerable position where its true risk profile is unknown even to senior executives. This practice, sometimes called shadow IT, is surprisingly common and reflects a sense that IT is as often an obstacle as an enabler.

The risk practitioner should evaluate and assess the approach of the enterprise to accepting new technologies and the attitude of the security team and IT operations teams toward reviewing and securing the new technologies as they become available. The risk practitioner is considerably more likely to get the attention and support of senior management by leading the effort to demonstrate how new technologies can be safely incorporated into the enterprise than by adopting an obstructionist posture. Additionally, the risk practitioner can remind IT operations and security staff that the best chance of maintaining relevance in the decisions surrounding emerging technology is to proactively suggest how it can be put to use safely rather than seeking to reject its adoption.

4.7.1 Omnipresent Connectivity

As recently as the early 2000s, people connected on demand from fixed points tethered by cables and were otherwise disconnected. Improvements in wireless networking and the emergence of smartphones and IoT devices reversed this situation beginning in 2010, resulting in people tending *and expecting* to be constantly connected. Continued advances in the reach of networks, including the proliferation of satellites in LEO, promise to make it ever more difficult to find even the opportunity to be deprived of a connection except by conscious effort.

The ability to connect has led to demonstrable changes in how people behave. Details that were once painstakingly memorized can now be consulted for quick reference as needed; as a result, people are less likely to gain mastery of specific skills in advance of direct need. Complex tasks can now be observed in video form rather than described in step-by-step paper manuals, so written instructions have become less precise. The intense focus that was the hallmark of analytical tasks for centuries has been replaced with a

need to multitask and collaborate across disciplines; many people even seek distraction online while actively working.

For the risk practitioner, omnipresent connectivity means that it is harder to safeguard information, because people are both more able to share things and more inclined to do so. People are more likely to share updates about their actions, locations, and experiences on social media as they happen, including livestream video feeds that may be taken without notice to those around them. Many users of powerful mobile devices demonstrate minimal awareness of or even interest in basic concepts of cybersecurity and information privacy. Sensitive information might be recorded or photographed at almost any time—including by malware that users may not even be aware has been installed on their mobile devices.

Because this is a widespread phenomenon of social transformation, and its scope of impact is virtually unlimited, there is no single recommended response that a risk practitioner can take to address the risk it poses. However, security awareness training is generally accepted as a good practice for ensuring that staff members are made aware of the threats posed by malware, social engineering, and other attack vectors (see section 4.9 Security/Risk Awareness and Training). Role-based training for staff members with privileged access is increasingly common, and some production environments of a particularly sensitive or detail-oriented nature may choose to adopt work requirements that reduce or forbid the presence of mobile devices altogether. As with any risk action plan, such decisions should be based on the enterprise risk appetite and risk tolerance as established by management.

Internet of Things Devices

A growing number of practical devices leverage the TCP/IP protocol suite and communicate both among themselves and with IT assets. IoT devices encompass everything from “smart” light bulbs to climate control systems to appliances. In workspaces, IoT devices promise substantial cost reductions by allowing dynamic programming of thermostats, window shades and other energy-saving measures to align with employee work times. The adoption of these technologies was slowed by the global pandemic of 2020, because a great deal of work shifted to remote placement for spans that in some cases exceeded two years. As more enterprises opt to return workers to offices, however, IoT penetration of industries is likely to resume its upward trajectory.

Risk practitioners should be aware that IoT devices tend to prioritize functionality over security, even after some degree of market pressure prompted vendors to add basic protections. Smart devices have been successfully hacked and used as sources for network traffic floods against endpoints to deny service to legitimate users. Devices programmed to respond to verbal cues are obvious targets for attacks that seek to record or pass along information that may be overheard, and climate controls that can be manipulated over the internet could feasibly be altered in ways that greatly increase cost, make workspaces uncomfortable, or even cause physical damage.

Security is likely to continue to be a secondary concern for IoT devices because the basic tension between operating efficiency and security is hard to overcome; security features make things more expensive and slow them down. The functional tasks linked to IoT devices also tend to be seen as part of the physical plant or facilities area of concern, receiving relatively little scrutiny within system life cycles or enterprise architecture. Security processes that are commonplace in IT may not be part of the approach taken to designing IoT implementations from the outset. In many cases, the presence of these devices becomes known to information security staff only after they are already deployed, and enterprises find themselves reliant on compensating controls (see section 3.6 Control Design, Selection, Implementation, and Analysis).

The risk practitioner should anticipate the appeal of smart devices and inquire about any IoT plans or implementations already in place. Where possible, the risk practitioner should bring together facilities and information security staff before smart devices are deployed and encourage the use of the SDLC for IoT projects. Building solutions with security in mind tends to be both cheaper and more effective than trying to secure a deployed system after the fact. Where practical, it may be beneficial to place IoT traffic on a

separate network and treat that environment as hostile cyberterrain. This sort of guardrails approach can allow IT operations and security staff to advocate for the benefits of IoT while maintaining acceptable levels of risk, rather than creating conditions under which IoT capabilities might be brought into the enterprise as a form of shadow IT.

4.7.2 Massive Computing Power

As networking has expanded and gotten both faster and cheaper, it has become increasingly easy to connect multiple computers in ways that allow them to collaboratively process the same data in complex transactions. This connectivity advantage coincides with an increase in capability on a per-processor basis, as multicore processors have become standard and operating systems have gained the ability to leverage much larger amounts of memory. The combination of these factors, along with virtualization, is what makes cloud computing possible (see sections 4.2.6 IT Operations and Management Evaluation and 4.2.7 Virtualization and Cloud Computing).

For many enterprises, transitions to the cloud mean more easily predicted and controlled hardware utilization costs, smaller IT staffing requirements, and greater business flexibility. As previously discussed, there is also direct risk associated with moving to the cloud. However, the massive computing power assembled by cloud architectures has implications beyond assigning accountability in the event of disruptions.

Decryption

Organizations frequently rely on encryption (see section 4.8.6 Encryption) to safeguard their data should an unauthorized third-party gain physical access to a device or successfully authenticate to a user network. The assumption with encryption is that any files obtained will be unreadable without the correct key. Using computers to attempt to break encryption by finding the mathematical key to unlock it by brute force is nothing new. Until recently, it was infeasible that anyone outside a well-funded government agency would be able to assemble sufficient processing power to accomplish that task. The ability to rapidly provision computing power through cloud providers has eliminated this restriction, with pattern analysis and brute-force attacks now within the grasp of individuals or groups with modest means.

Quantum computing, based on principles of quantum mechanics that allow indicators to hold multiple binary states simultaneously, is also driving a revolution in computing capabilities. For some tasks, quantum computers appear to be no more effective than traditional processing, while they can perform others in dramatically reduced times. As the advantages of quantum computing become more widely understood, and prices fall, it can be expected that cloud providers will leverage these systems in ways that provide the most benefit within their overall architectures. Meanwhile, the aggregate computing power available within the cloud continues to grow.

For the risk practitioner, this means that it is difficult to predict how long an encrypted file might protect data if it were stolen. Encryption remains a vital part of information security, but it cannot be taken for granted that data is safe simply because it is encrypted. Fortunately, this is an area in which research remains reasonably ahead of fielded capabilities, and quantum-resistant algorithms have already begun appearing. By maintaining awareness of these offerings and encouraging their use where appropriate, risk practitioners may be able to reduce the risk posed by quantum computing to acceptable levels. However, the sufficiency of this approach depends in large part on the completeness and accuracy of an enterprise data inventory, including knowledge of what algorithms are currently used to encrypt archived data. Without such knowledge, outdated methods of encryption may remain in use despite the availability of updated algorithms, leaving the enterprise exposed.

Deepfakes

People tend to assume that they can trust what they see and hear. In the era of massive computing power, this is no longer the case. False audio and video can now be created using digitally manufactured

imitations of a person based on samples. For political figures and celebrities with significant public profiles, obtaining these samples is astonishingly easy: many people express themselves with a wide variety of facial and body movements as well as verbal intonations and cues in any recorded presentation. Processing these inputs as a baseline, algorithms can reconstruct convincing replicas of human movement where one person is redrawn as another, while words and phrases are filtered in ways that make them sound like the target's voice.

It is possible to digitally detect these "deepfakes," but doing so takes considerable expertise. The typical person listening on the other end of a phone or watching a replayed video would be quite convinced by basic sensory recognition that the impersonator was who they claimed to be. This technology poses substantial challenges for organizations that have procedures to authorize financial transfers, release data or carry out other potentially sensitive tasks on verbal or visual approval of an authority figure.

Risk practitioners operating in high-risk environments can guard against deepfakes misdirecting operations through a combination of security awareness and administrative controls. For instance, requiring that a particular transaction not only have the verbal approval of the CEO but also written approval from another executive, or using a dedicated callback number to obtain confirmation after receiving initial outreach, can help inoculate an organization against this kind of technical deception.

Unfortunately, no such protective measures are sufficient to guard against impacts to public opinion that may arise from falsified video or audio recordings, particularly when dealing with enterprises or issues subject to substantial public tensions. Many people for whom it is easiest to gather the data points needed to produce deepfakes are in positions where reputational risk is significant. Until there is an easy way to identify deepfakes and a mutually trusted third party to do so, it can be expected that deception for political or commercial gain will remain an emerging trend requiring a robust risk response.

For more information regarding deepfake video, refer to section 3.13.2 Impact of Emerging Technologies on Design and Implementation of Controls of Controls.

Big Data

Proliferation of devices and computing power in an environment of omnipresent connectivity has led to an enormous expansion in the volume of data—more than hundreds of millions terabytes every day. Storage costs have fallen dramatically with the advent of cloud computing, and increased connectivity has made accumulation of data an everyday occurrence. In many industries, analysis of these vast amounts of data has in turn shifted from delivering competitive advantage to being a necessary precondition of business for many organizations.

For all the benefits that big data has to offer, data-centric enterprises also face risk. Accumulation of substantial volumes of data has implications for data privacy. Enterprises that have data piling up on a constant basis also struggle to keep it from becoming disorganized "dark" data that resists correlation and analysis. Finding the right experts to design effective data analytics is a growing concern, and retaining data beyond its intended use can result in reputational risk as well as fines or penalties for breach of contract under conditions where collection was explicitly limited to particular periods.

Data privacy risk is perhaps the most unpredictable and dynamic area of risk associated with cybersecurity (see 4.10 Data Protection Principles).

4.7.3 Blockchain

Data has been organized and stored in databases for decades. Traditionally, databases have been stored as tables and accessed either hierarchically or relationally. Recently, the capability has emerged to store data in blocks that are chained together, maintaining a timeline of transactions that allows the history of data to be determined without centralized processing. The absence of centralization facilitates extraordinary transparency in transaction logging that is inherent to the blockchain structure. The chain structure also

makes it very difficult to falsify a blockchain entry, because each entry contains both its own digital hash and the hash of the block before it (see 4.8.6 Encryption for more information).

Blockchain has been implemented in pseudo-currencies based on cryptography (e.g., Bitcoin, Ethereum). However, its potential implications extend beyond currency. Blockchain has been touted as a way to revolutionize banking, healthcare, property titles, and even voting. Some of the promises made may prove to be baseless hype. However, risk practitioners in industries affected by blockchain should take care to remain apprised of what developments are underway.

4.7.4 Artificial Intelligence

For decades, scientists have attempted to create in computers the ability to behave autonomously in a manner that mimics human intelligence. Precisely what this means has long been subject to debate; as machines become increasingly capable of processing logical decision matrices, the parameters for intelligence tend to exclude what is accomplished, so that AI is sometimes seen as *by definition* an unattainable standard. One approach, suggested by computer scientist Alan Turing in 1950, is that a computer could be called intelligent when it was able to engage in behavior indistinguishable from a human. This approach has been both praised and criticized, with the principal criticism being that observed behavior does not demonstrate intent.

By the time of the global pandemic in 2020, digital assistants such as Apple Siri or Windows Cortana were already capable of answering questions based on queries that leverage omnipresent connectivity. Device hubs such as Amazon Alexa and Google Home extended this capability to manipulation of IoT devices, and considerable effort was being put into the provisioning of self-driving cars. However, the debut of ChatGPT in 2022 introduced society at large to GenAI, a type of AI that could draw upon rules established in training to parse virtually any request and produce a response that would generally be accepted as human by a typical reader.

Risk practitioners involved with AI should keep in mind that there can be distinctions between human and rational response and that any rules that can be positively verified can likely be exploited by those with intent and awareness. Even without intentional manipulation, there is considerable divergence between human and algorithmic goals. ChatGPT has demonstrated a willingness to share information that it knows is false (i.e., lie) and the ability to create new assumptions based on erroneous reasoning (referred to researchers as “hallucinations”). The developers behind the system have also directly admitted that they do not understand how it works, making traditional forms of testing such as decision-tree analysis unhelpful.

Oversight of AI is especially important in cases involving ML, algorithms designed to refine themselves over time based on results. Humans know that habits are highly useful and make it possible for us to do things that would otherwise require far too much effort; however, bad habits may be very difficult to break. The same basic dynamic applies to ML systems. Where “improvement” is poorly or incorrectly defined, iteration aimed at refining outcomes may result in lasting deviation from goals. Heuristic systems used in intrusion detection and prevention are one area of concern for ML, where an errant determination that malicious traffic is normal could result in willful blindness to an intrusion underway.

Risk practitioners not directly involved in AI or ML development activities may find that these considerations still affect them. Many statements of work now require disclosure of the use of AI to develop deliverables, while an increasing number of data-use agreements prohibit the use of covered data for ML modeling or training. At the same time, falling costs for GenAI in particular have resulted in these capabilities being built into an increasing number of tools, including automated transcription services and text recognition software. To ensure that an enterprise does not take on unaccepted risk, the risk practitioner should look for ways to identify where and how AI and ML capabilities are being used and advocate for active management approval of such use with full knowledge of the implications.

Additionally, the use of AI presents numerous areas of nontechnical risk, which many enterprises may overlook—namely, ethical and environmental impacts of using AI solutions. Biased or incorrect outputs

that directly impact human rights and safety (e.g., automated loan approval, healthcare diagnoses) can result in reputational and legal damage to enterprises. Additionally, the use of sensitive and personally identifiable information (PII) to train AI models presents privacy and intellectual property risk that may be overlooked using standard risk identification and assessment processes.

The risk practitioner should ensure that privacy impact assessments (PIAs) and fundamental rights impact assessments (FRIAs) are part of the AI risk assessment process.

Part B: Information Security Principles

One goal of risk management is ensuring that technology used in the enterprise is adequately protected, secure, and reliable. As with IT, the risk practitioner need not be an information security expert but should be sufficiently knowledgeable as to ensure that the risk assessment and response program evaluates new technology and provides effective advice on how to deploy and use it within acceptable risk boundaries wherever possible. Some risk-based considerations regarding the deployment of new technology include:

- Training for users and administrators
- Creation of policies and procedures
- Inclusion of systems in backup schemes and continuity plans
- Assignment of risk ownership
- Consent of information owners for any technology that may handle sensitive information
- Review of legal or regulatory requirements
- Assignment of responsibility for monitoring and reporting on proper technology use
- Adoption of zero trust architecture

Older systems, commonly called “legacy” systems, frequently require special attention because of gaps between their designs and current security standards. Legacy systems might lack security features entirely or have features that are misaligned with observed threats. Systems reaching the end of their operational life may also be more susceptible to failure. The risk response options for legacy systems tend to be limited due to the cost involved in replacing or upgrading them. Some legacy systems may not be replaceable at all—a common occurrence for operational technology in industrial environments. Under such circumstances, the risk practitioner’s role is not to reject a particular course of action but rather to work with the risk owner to reach an acceptable level of risk. Compensating controls—such as additional backups, spare parts, strong network segmentation, cross-training, documentation, and increased monitoring of systems performance—may be effective supplements to existing security where conventional improvements are either technically infeasible or cost prohibitive.

Every system is the responsibility of a system owner. The owner of the system is usually a senior manager in the department for which the system was built. For example, the owner of financial data and the financial systems of an enterprise might be the comptroller or chief financial officer (CFO). The system owner is responsible for the proper use and operation of the system and usually must approve expenses for system implementation, changes, upgrades, and removal. Ownership does not mean literal responsibility for all actions taken. Typically, system owners engage the IT department or an external supplier to manage and operate systems under their ownership on behalf of their functional areas. However, transference of responsibility does not mean transference of accountability, except in rare cases in which a supplier might accept full legal accountability for damages and losses. Responsibility can be delegated; accountability cannot.

Large enterprises may have many system owners from various departments, which can make it difficult to manage, oversee, and ensure consistent operation of the systems in a coordinated fashion. For instance, an information system that supports the sales department may operate in a considerably different cultural environment than an information system that supports the finance department, and this difference in culture may affect the way the system is managed and protected. If the protection for each system is the sole responsibility of the owner of that system, then significant differences can exist in how the security

and risk for each system is enforced. This is a substantial problem in modern networked enterprises, because information sharing and system dependencies make it likely that a breach or vulnerability in any one system is a risk to the entire enterprises. For this reason, an organization should take an enterprise approach to security to ensure consistent, reliable, and secure operations.

Common methods of providing enterprise consistency include change control (see section 3.4 Issues, Finding, and Exception Management), the adoption of an enterprise architecture and technology roadmap (see section 4.1 Technology Roadmaps and Enterprise Architecture), and system authorization (see section 4.8.2 System Authorization). Accurate asset inventory and proper data classification also informs and promotes an overall information security strategy.

4.8 Security Concepts, Frameworks, and Standards

Key Takeaways

- Information security is a tradeoff between confidentiality, integrity, and availability (CIA), which collectively create a fourth effect called nonrepudiation.
- Systems that are formally assessed and authorized before they are used are less likely to have unaccepted risk.
- Separation of duties (SoD) and job rotation reduce the risk of collusion among staff to exploit weaknesses in enterprise controls.
- Authentication using more than one factor is stronger than any single factor.
- Encryption enables many security functions but does have drawbacks, such as slowing down processing.

IT risk is often linked to information security, which is the protecting of information and information systems (including smart technology) from risk events. Information security controls are deployed based on risk, and risk is the primary justification used to support information security activities.

Some enterprises have a mature risk management process able to quantify risk with a high level of accuracy. In other enterprises, the term “risk” may be poorly understood and represent an emotional value based on perception. Often, the predicted impact of an undesired event considers only direct, immediate effects, whereas actual events may have repercussions that affect tangential aspects of the business or are discovered long after the event has occurred (such as damage to reputation).

4.8.1 CIA Triad

The risk practitioner may find it helpful to evaluate an information system or data source on the basis of CIA, the three principles from which all other characteristics of information security are derived. By considering information and systems according to this model, it becomes easier to identify whether, and how, a compromise or failure in one or more of these areas would affect the enterprise. For purposes of risk identification, simply noting that an impact may occur is sufficient; during risk assessment, the practitioner draws on these findings to develop a more detailed analysis that includes the particular extent of impact from each area of compromise.

It is important for the risk practitioner to have a solid understanding of the interrelationship between the three principles in the triad as well as nonrepudiation, a fourth principle derived from them. There are typically trade-offs between the three principles in any system, making it impossible to simultaneously increase one of them without either decreasing at least one of the others or substantially increasing cost. For instance, increasing confidentiality typically increases processing time, which reduces availability. The CIA triad shown in **figure 4.12** illustrates this relationship.

Figure 4.12—The CIA Triad

Source: ISACA, *Cybersecurity Fundamentals, 3rd Edition*, ISACA, USA, 2021

Confidentiality

Confidentiality refers to the intentional secrecy and privacy of data. Accordingly, a breach of confidentiality means the improper release of information, such as disclosure to an internal or external recipient not authorized to access it. Confidentiality is often discussed in terms of the need to protect military secrets or special categories of information, such as PII, personal health information (PHI), intellectual property, and other specific types of data protected by law or regulation. However, the basic principle of confidentiality is to ensure that disclosure does not occur to any recipient unless authorized by the information owner.

In identifying risk related to confidentiality, the risk practitioner should look for policies or behaviors that violate either or both of the following principles:

- **Need to know**—Individuals should be given access only to information that they need to perform their job functions. For example, most users do not need to see credit card numbers; therefore, the numbers are masked or hidden except for the last few digits, which protects the cardholder data from being compromised.
- **Least privilege**—The level of data access afforded to individuals or processes should be the minimum needed to perform their job functions. For instance, someone who needs to review data should not be able to edit or delete it.

Policies, practices, or behavior that does not reflect these principles are a warning flag to the risk practitioner of possible risk related to confidentiality.

Integrity

Integrity refers to protection against improper modification, exclusion, or destruction of information and applies to actions taken by both authorized and unauthorized users as well as processes or activities operating on the system. Whenever data is changed in a manner other than that intended by the data owner, integrity is compromised.

Maintaining integrity is typically a rigorous process that relies upon multiple levels of error checking and verification that may be difficult for the risk practitioner to fully evaluate without technical expertise. The principle of least privilege is also critical when identifying risk related to integrity, particularly when it comes to access by system processes and other memory-resident applications. Whenever a user or process has the power to change or delete data, the ways in which it interacts with data must be carefully considered to determine whether there is an integrity risk.

Environmental factors can also create risk related to integrity. High temperatures and slightly inadequate electrical input both have the potential to result in computational errors that might not be detected.

Availability

Availability refers to providing timely and reliable access to information. In some cases, such as industrial control systems operating machinery or regulating power generation, near-real-time availability may be essential for safety and proper system operations.

When asking what levels of availability business processes require, risk practitioners should anticipate an initial answer from process owners that systems and data are essential and require 100% availability. In most cases, this is not accurate, as rapidly becomes clear when the financial costs associated with guaranteeing true 100% uptime are presented. From there, the risk practitioner should expect to work with the business to determine specific requirements and align these with what the organization is willing to pay to have higher availability. One way to identify potential availability risk is to compare current levels of availability with required levels; where there is a gap, there is a risk.

Nonrepudiation

In information systems, activity is often either anonymous or only weakly traceable to a particular individual or process. Nonrepudiation refers to a positive guarantee that a given action was carried out by a given individual or process and is an important part of tracing responsibility and enforcing accountability. Digital signatures and certificate-based authentication in a public key infrastructure (PKI) are examples of controls whose proper implementation and use can provide nonrepudiation. In contrast, while shared or generic logon credentials provide no assurance, the level of assurance afforded by individual usernames and passwords is relatively weak, because these can be shared or guessed. For purposes of risk identification, the risk practitioner should look for evidence of nonrepudiation in situations in which actions may have significant impact on an enterprise, such as code approval, deletion of records or disbursement of funds.

4.8.2 System Authorization

Many enterprises combine an objective assessment with formal acceptance of the risk associated with the installation and operation of an information system. Introduced by the US military as certification and accreditation (C&A), this process is now referenced in the US National Institute of Standards and Technology (NIST) special publications relating to risk management as security assessment and authorization (A&A).[44] By either name, the process serves the same purpose, which is the explicit authorization of a system to operate prior to it being allowed to do so.

During assessment, an information system is thoroughly reviewed to determine the security of its design, development, testing, deployment, and operations. The evaluator examines the technical and nontechnical aspects of system operations to ensure that the risk associated with the system has been identified and documents any mitigating controls that may be in place. This means evaluating assessments, system documentation, and the results of technical tests to verify that the system will operate within an acceptable level of risk, so the evaluator should be a technical and process expert. The culmination of the assessment process is a report to a suitably empowered senior manager recommending whether to authorize operation of the system. It is a good practice for evaluation to be done in parallel with the SDLC to ensure that any unacceptable risk is identified promptly and addressed with system and project managers.

Authorization is the official decision by a senior manager—sometimes called an authorizing official (AO)—to approve an information system for operational use. This decision is the explicit acceptance of the risk documented in the evaluator's report, and it may come with caveats. For instance, a system may be authorized to operate only under certain circumstances or at particular time frames. Certain risk also may be accepted for a limited time on the basis of response activities that are already underway but have not yet been completed, with the requirement that the system cease operation if projected deadlines are not met. Although the AO typically concurs with the assessment recommendation, the decision to accept risk is ultimately their responsibility as a senior manager accountable for business matters, not the evaluator who

performed the assessment from a security perspective. This approach reflects the general practice of risk management as a function that serves the business interests of the enterprise.

Upon receipt of authorization, the system owner may operate the system according to the restrictions and for the period granted in the authorization. Depending on the maturity of the organization and its processes, this may be indefinitely or some number of months or years. Authorization typically comes with the caveat that any substantial changes in the system or the organizational risk profile require a new evaluation and reauthorization of the system. In many modern implementations of system authorization, a system of continuous monitoring is deployed to keep risk aligned with accepted levels.

4.8.3 Separation of Duties

Errors and intentional malicious acts are more difficult to detect when single individuals can complete potentially risky processes on their own. SoD is a basic internal control that prevents or detects errors and irregularities by assigning responsibility for initiating and recording transactions to someone other than the person responsible for the custody of assets. Most often, this takes the form of requiring one person to review and approve the work of another person. For example, a request for a large payment may need to be countersigned before it is processed, or a developer may need to submit code to a testing team to have it moved into production. SoD may also mean requiring two people to participate in a task simultaneously (often called dual control), for example, a system used to control release of nuclear weapons.

The key to SoD is mutual exclusivity. SoD does not guarantee security, because it can be circumvented when all participants in the process agree to work together to bypass the intended effect of the control (collusion). However, because it is difficult to establish collusion, and especially challenging to maintain it over time, effective SoD increases the odds that an incorrect or fraudulent transaction will be detected and addressed.

4.8.4 Cross-Training and Job Rotation

Enterprises can reduce their reliance on key staff by training multiple people with the same skills, making it possible for any of several individuals to step in to fill a vital role as needed. In many cases, this takes the form of cross-training, in which people on the same team are trained in one another's roles. Cross-training makes it possible for an enterprise to rotate people between different jobs.

Although job rotation is typically associated with business continuity and enterprise resiliency, it is also an effective security mechanism because it changes who is involved in which roles at which times, reducing the potential for collusion and increasing the odds that prior collusion can be detected by someone who is not part of the scheme. In environments where there is substantial concern regarding the potential for collusion, job rotation may take the form of mandatory vacations in which people are removed from their regular duties specifically to allow independent verification.

One risk associated with cross-training is that employees with substantially broader skill sets may be more attractive to other employers. The rotation of personnel may also result in decreased efficiency during times of transition, and employees who know that they are about to move out of jobs may be less diligent than those who expect to remain in them. Nonetheless, in high-risk environments, this potential loss of productivity may be warranted. This is particularly common in financial institutions and positions that deal with moving large amounts of money.

4.8.5 Access Control

Managing access to information systems and data is one of the most challenging aspects of information security. Access control is commonly addressed through the concepts of identification, authentication, authorization, and accountability (IAAA).

Identification

With a unique identifier assigned to every individual, device or process that has access to a system, it is possible to track and log activity on a per-user basis, creating the possibility of a targeted investigation were a problem to arise. Identification is often provided through a user ID, customer account number, employee identification number, or other unique element. Risk practitioners should verify that the process of issuing an employee ID is reasonably secure and requires proper authorization.

Authentication

Authentication is the process of validating an identity once it is presented. The purpose of authentication is to ensure that one person cannot spoof an identity or masquerade as another user, which includes prevention of ID sharing by more than one person.

Authentication is done using one or more of three factors:

- Something you know (e.g., user ID, password)
- Something you have (e.g., token, authenticator)
- Something you are (e.g., fingerprint, iris scan)

Authentication by knowledge means presenting a password, code phrase or other secret value to validate identity. Complex knowledge questions may be extremely personal, include artistic or visual representations, exercise particular skill sets in certain ways or otherwise map to something that arbitrary individuals would be unlikely to know. However, knowledge is often subject to replay attacks, even when what is asked is complex—sometimes more so, because complex passwords or knowledge responses tend to be used for an extended period of time. Time is the enemy of knowledge authentication, because any knowledge question can eventually be figured out, allowing one person to log in as another. Therefore, changing passwords on a regular basis is recommended even in high-complexity environments.

Authentication by possession relies on some sort of item, such as a smart card, token, or ID badge. Direct possession may be sufficient, or the user may generate a one-time password from a token using a preshared algorithm that cannot be guessed. Authentication based on possession was once the subject of considerable expense when installing the infrastructure, issuing the cards or tokens, and operating and maintaining the system. Widespread ownership of mobile phones capable of running complex applications has dramatically reduced the cost, allowing possession-based authentication to become relatively commonplace. The ability to digitally lock mobile phones also mitigates a longstanding concern that a lost token might be used by an imposter if it has not been reported as lost or stolen. However, one downside remains: should the means of authentication be lost, stolen, or damaged, the legitimate user may be denied access without easy recourse. Where availability is a primary concern, the risk practitioner should take care to examine what workarounds may be in place, keeping in mind that any workaround also represents a potential area of vulnerability.

Characteristic authentication relies on biometrics, factors present in physiology (e.g., fingerprints, iris scan, palm scan, etc.), or behavior (e.g., voice print, signature dynamics). Like possession, access to certain basic biometrics that were once expensive has been made attainable through the distribution of mobile phones, which may be able to unlock functions based on facial recognition or other fingerprint analysis. Purpose-built systems can even monitor body movement and other indicators to cut off access should there be indications that a device has changed hands. However, some users find biometrics to be intrusive and may be resistant to it. In addition, biometric data may be subject to laws and regulations governing privacy, with potentially severe penalties in some jurisdictions should the data be compromised. Also, while it is generally assumed that a person would not lose characteristics in ways that might deny access, this assumption does not hold under all conditions; for instance, soldiers or workers in industrial environments might experience physical injuries that affect their eyes or limbs.

Authentication of devices or network nodes may also use characteristics as determining factors. Node authentication is used when limiting access to certain devices through the identification of IP addresses,

MAC addresses or serial numbers of devices that are attempting to log on. These characteristics avoid the concerns of human biometrics because privacy is not a concern for devices; however, it may be possible to falsify (spoof) digital characteristics. Where positive control is needed for network endpoints or appliances, use of system-level digital certificates can help positively establish identity and broker authentication using protocols such as 802.1x.

Multifactor Authentication

Single factors of authentication are rarely considered strong enough on their own to safeguard modern information systems. By combining more than one type of authentication during the login process, organizations can establish strong authentication that is difficult to breach in a reasonable time. This could include using a password with a smart card, a biometric indicator paired with a smartphone-generated code, or a combination of inputs from all three factors. Such arrangements are commonly referred to as multifactor authentication (MFA).

The most common MFA implementations in use today combine traditional passwords with codes sent to or generated by applications on personal smartphones. Risk practitioners should be aware that these arrangements, while convenient, make authentication reliant on access to devices that are outside of organizational control. Should a mobile device required for MFA be unavailable, the result is likely to be a temporary inability of a valid user to authenticate to organizational information systems. Smartphones are among the most easily damaged, stolen, and lost items in individual possession. Numerous examples also exist of actors using social engineering to convince phone providers to port existing numbers to new devices on false pretenses.

Authorization

After a user has successfully authenticated, the system must provide that user with appropriate levels of access. Authorization refers to the privileges or permissions the person will have, which may include read-only, write-only, read/write, create, update, delete or full control over data. Permissions may be applied on a per-file or per-folder basis. Proper employment of least privilege is important to ensure that employees only have the level of access they require to perform their job functions.

Isolation

Authorization is typically granted only for a limited period, which may be established based on an inactivity timeout or a set expiration date based on when permissions are required. For instance, access to a building, network or application might only be allowed during normal working hours, and outside those hours, access not allowed even with a valid account. Similarly, where location tracing places the source of an authentication request outside a likely geographic area, additional verification may be required, or the access attempt might be blocked entirely. This isolation on a time- or location-delineated basis prevents a user from using account privileges at times when they should not be required and allows an organization to maximize the effectiveness of its controls by reducing the potential scope of monitoring.

Accountability

The final part of the IAAA model is accountability. Typically accomplished through auditing, this action relies on systems logging or recording activity on a system in a manner that indicates the user IDs responsible for the activity. The effectiveness of accountability measures relies on both unique user IDs and effective authentication methods and ensuring that the logs are protected from modification or alteration. In order to prevent a user from disabling the logging function or altering log data that implicates their own account in suspicious or malicious activity, audit logs should not be changeable by operations staff—even administrators. Logs also may contain sensitive data, so even view access to log content should be strictly controlled based on clear business need.

4.8.6 Encryption

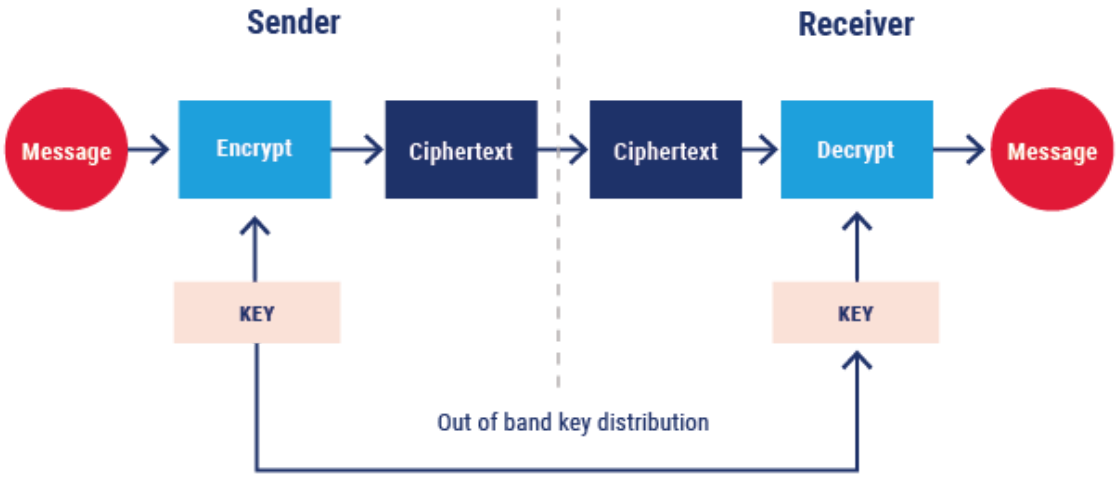
Encryption is a mathematical means of altering data from a readable form (plaintext or cleartext) into an unreadable form (ciphertext) in a manner that can be reversed by someone who has access to the appropriate numeric value (key). The foremost use of encryption is to protect the confidentiality of data by making data unreadable to anyone who is unauthorized. The science of creating encryption is called cryptography, while the broader study of creating and solving cryptographic puzzles is called cryptology.

In addition to confidentiality, novel uses of data encryption can also provide several additional risk management benefits, including:

- Integrity
- Nonrepudiation
- Access control
- Authentication

Mathematically, encryption comes in two basic forms—symmetric and asymmetric—each of which has its own strengths and weaknesses that can be used in a variety of ways. The risk practitioner should be familiar with these concepts of encryption, which are central components of data protection (**figure 4.13**).

Figure 4.13—Symmetric Cryptography



The most common symmetric key cryptographic system currently in use is the Advanced Encryption Standard (AES), a public algorithm known as a block cipher because it operates on plaintext in blocks (strings or groups of data values). AES supports keys from 128 bits to 256 bits in size and is found in a wide variety of encryption applications, including file transfer, content presentation, and the creation of VPNs.

Because the length of a key determines the number of possible mathematical combinations, shorter keys pose an inherent security problem as processing power increases. Where shorter keys are used, the entire key space might be tested against ciphertext by large computer systems within a relatively short period of time, via a technique aptly known as brute force. The effectiveness of this technique has expanded rapidly with the advent of cloud computing, which allows provisioning of massive computing power on a short-term basis. AES includes a number of advanced mathematical techniques that make its ciphertext stronger than prior algorithms. Nonetheless, ongoing advances in computing power virtually guarantee that any algorithm in use will eventually be rendered obsolete. Additionally, risk practitioners should also be aware

that even the strongest algorithm with the most robust keys is only as secure as its key management system.

Symmetric key cryptography has two major disadvantages. One is the need for one party to deliver keys to another with whom it would like to exchange data. Where communications are established on a point-to-point basis between trusted parties, this may be workable through a variety of physical (out of band) methods, after which an existing secure channel can be used to send updated keying information on a periodic basis. However, there are numerous environments (such as e-commerce) in which customers are unknown and not trusted entities, making brokering a connection more difficult. Such arrangements are also at odds with the need for dynamic connections lasting only a short time.

Once such a channel is established, there are limits to what it can accomplish. For instance, if the same symmetric key is shared to all participants on the channel, there is no way to be sure which participant in a given key network originated a particular message, because everyone is using the same key. However, the alternative is to have a distinct key shared between every pair of participants, which creates exponential growth in key pairs for every added recipient.

Asymmetric Algorithms

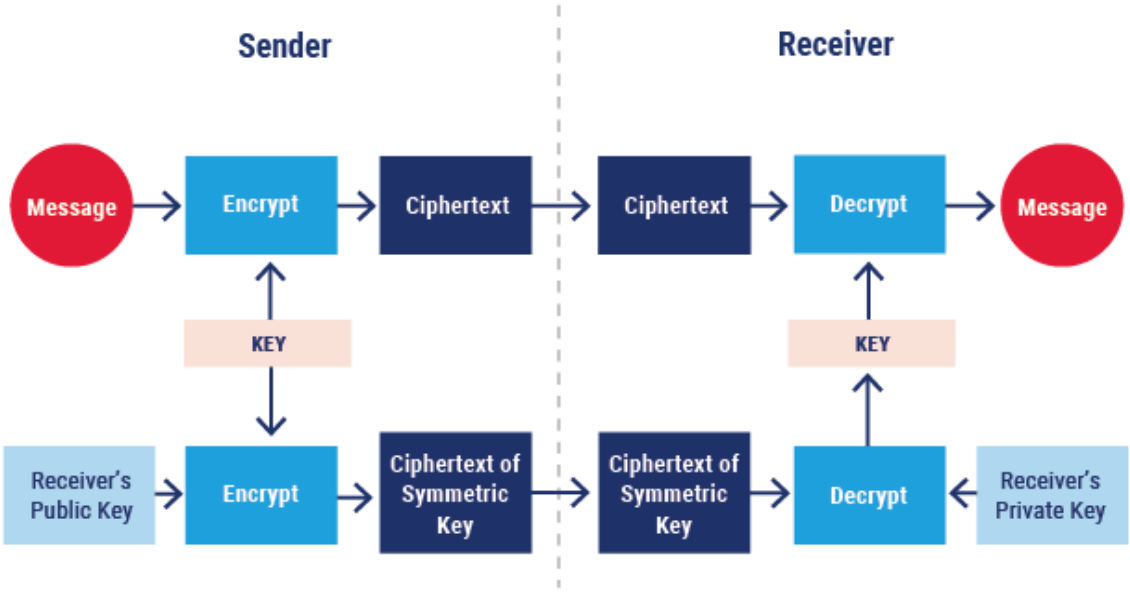
Asymmetric key cryptographic systems evolved to address the issues that arise with symmetric key cryptosystems. The intent of an asymmetric algorithm is to provide a way by which a secure channel can be created between parties that lack prior awareness of one another.

In 1976, Whitfield Diffie and Martin Hellman published the first public example of encryption based on two different keys, a technique that has since been known as the Diffie-Hellman model. In a Diffie-Hellman setup, two mathematically related keys are created: a private key and a public key. It is computationally infeasible to determine the value of one key from the other, but the manner of their generation means that each has the effect, when used in an appropriate asymmetric algorithm, of creating ciphertext that only the other has the ability to return to plaintext. As a result of this relationship, the public key may be freely distributed and used as the means of encrypting any message that should be readable only by its creator, who has sole access to the private key that allows the messages to be decrypted. Additionally, the only messages that the public key can decrypt are those that were encrypted by the private key, to which its creator has sole access, so any recipient can be certain that the key creator was the true author.

Because asymmetric algorithms involve sharing the public keys of a public/private key pair, they are commonly referred to as “public key” algorithms. Each party using public key cryptography only needs one pair of keys, and the ability to freely share the public key overcomes the challenges of scalability seen in symmetric key cryptography.

Asymmetric algorithms are computationally intensive and slow relative to symmetric algorithms. For that reason, asymmetric cryptography is typically used only to encrypt short messages. The most common use of asymmetric algorithms is to distribute symmetric keys that can then be used by the participants for fast, secure communication, as seen in **figure 4.14**.

Figure 4.14—Using Asymmetric Algorithms to Support Symmetric Cryptography



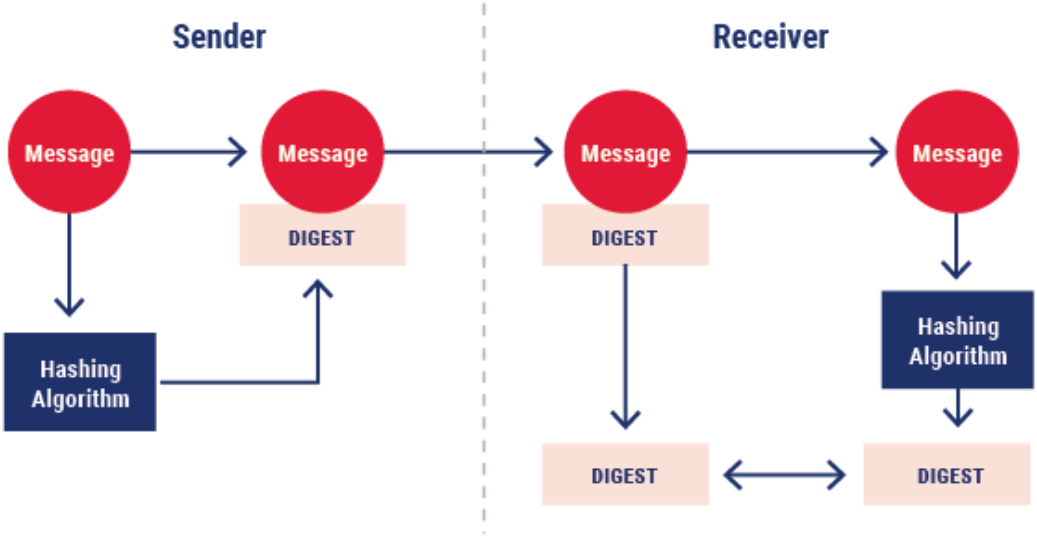
Message Integrity and Hashing Algorithms

Early computer networks used voice-grade telephone cables with limited bandwidth. The combination of slow speed and interference meant that error correcting was needed to ensure that what was received matched what was sent. Parity bits, checksums, and cyclic redundancy checks (CRC) were effective in detecting accidental errors, but these mechanisms added data to each transmission. To reduce both the amount of data and the computational power needed for error checking, cryptologists developed the concept of hashing, which is the mathematical transformation of data using an algorithm whose result is predictable, repeatable, entirely dependent upon the content of the message, and of a fixed length (regardless of the length of the original message).

For any message provided, a hash algorithm calculates a fixed-length value commonly known as a digest, fingerprint or thumbprint. The length depends on the hash algorithm used; for example, SHA1 generates a digest of 160 bits, while SHA512 generates a digest of 512 bits. When a sender wants to ensure a message is not affected by noise or network problems, he or she can hash the message and send the digest along with the message to the receiver. The receiver can then hash the received message and verify that the resulting digest matches the digest sent with the message, as shown in **figure 4.15**.

Hashing by itself provides effective protection against accidental changes in a message, such as those caused by interference, and this was its original purpose. However, a malicious user who intercepts a transmission that includes a hash will not be deterred by hashing, because they can create a new digest after altering the message. To guarantee integrity against intentional and accidental changes, cryptologists extended the basic idea of hashing to include features of public key encryption, resulting in digital signatures.

Figure 4.15—Verifying Message Integrity Using a Hash Function



Digital Signatures

A digital signature combines a hash function with the ability of public key encryption to prove the author's identity. The hash function allows the receiver to verify that the message was not changed since the digest was added, because the hash of the received message is the same as the digest attached to the message. The receiver also knows that the digest came from the original sender, who has encrypted it with his or her private key. To access the digest, the recipient's ability to decrypt the digital signature with the sender's public key means that it must have been encrypted with the sender's private key and is, therefore, the genuine digest for the message as originally written. Moreover, the sender cannot plausibly deny it, because *only* the sender's private key could have encrypted it. This combination of verifiability and nonrepudiation makes private-key encrypted digests behave comparably to physical signatures, which is why the process of generating them is known as digitally signing messages.

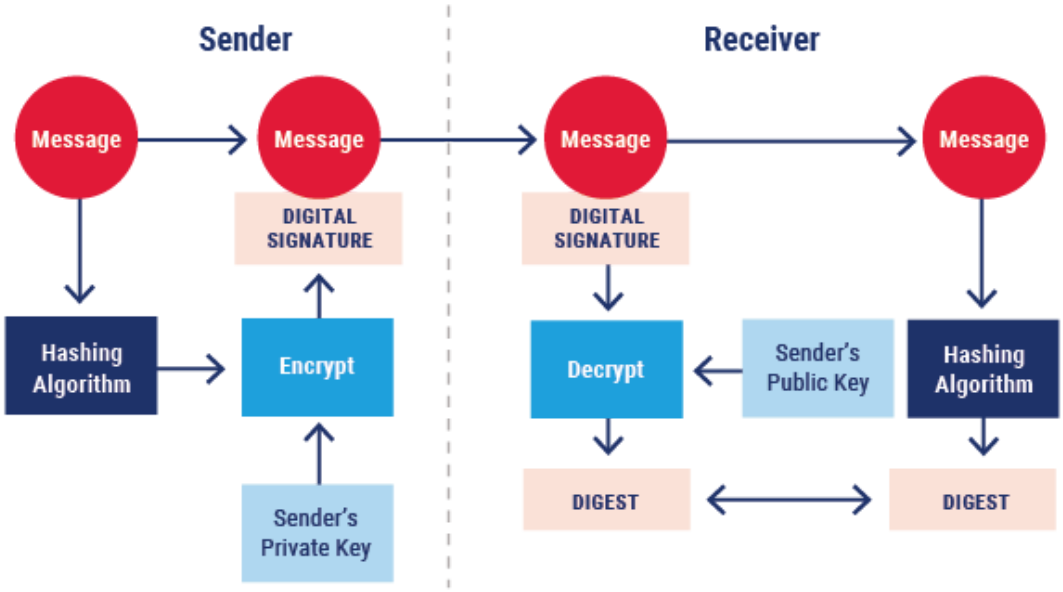
Figure 4.16 illustrates the use of digital signatures to verify integrity and proof of origin.

The risk practitioner should remember that just as physically signing a document does not keep others from reading it, digitally signing a message applies encryption only to the digest and does not make the message content confidential. A message may be:

- Encrypted and not signed (confidential but lacking integrity or nonrepudiation)
- Signed and not encrypted (not confidential but with integrity and nonrepudiation)
- Signed and encrypted (confidential with integrity and nonrepudiation)

Only a message that is both signed and encrypted is protected against unauthorized viewing, guaranteed to have arrived in the form that it was originally sent and known to have originated from the person who claims to have sent it.

Figure 4.16—Verifying Message Integrity and Proof of Origin Using Digital Signatures



Certificates

Public key encryption ensures that the holder of a private key can decrypt what is encrypted with the corresponding public key. However, it does not prove that the person who owns the public key being distributed is who he or she claims to be. Certificates link public keys with specific owners by relying on the endorsement of a trusted third party known as a certificate authority (CA). The CA verifies identity by other means and generates the certificate on behalf of the owner of a public key so that the owner can prove that the public key belongs to them. By relying on this trust, the recipient of a message digitally signed with that public key of the certificate knows that the message was signed and sent by the claimed sender. The same person also knows that using the public key to encrypt a response will yield a message that only the intended recipient can open.

The format of a certificate is based on a standard called X.509, which ensures that certificates can be accessed by most Web browsers, systems, and software even if they are issued by different CAs. Each certificate is valid for a defined period of time (typically one year from the date of issue). However, the owner of a certificate may cancel it at any time during that period by notifying the CA, which will put the certificate on a certificate revocation list (CRL). Requests to validate a certificate that is on a CRL result in a notification that the certificate has been revoked, warning that the certificate should not be trusted as a means of verifying identity.

Public Key Infrastructure

Public key infrastructure (PKI) refers to the overall implementation of certificates and the CAs needed to issue and verify public key cryptography. With a given PKI implementation, there is a top-level ("root") CA that manages all the certificates for users within the architecture. Through the root CA and any subordinate CA delegated by the root, any member of the group can gain access to the certificates of the other group members. This ensures that communication is secure and can only be accessed by the appropriate parties.

PKI implementations may be connected to one another and allow certificate verification using an external CA. When members of different PKI implementations are linked by relationships established between their respective CAs, a cross-certification agreement should be in place to provide a policy basis for this inter-connectivity. Additionally, the risk practitioner should ensure that mechanisms for certificate management are in place so certificates can be renewed prior to expiration. Once a certificate expires, results may

include loss of access to encrypted messages and communications channels that depend on PKI-authenticated access.

Disadvantages of Encryption

Although encryption is extremely useful and is a central component of most data protection strategies, there are drawbacks to its use. One is that encryption requires processing and its demands increase with the length of the key and strength of the algorithm. Encryption also increases network traffic based on the need to verify certificates, particularly in cases in which large numbers of small messages are being passed between distinct end points. The increased processing and transmission demands placed on IT infrastructures by encryption mean that it should be used only when necessary. Encryption is thus not a purely technical control but rather depends, in part, on policy at the organizational level. The need for policy extends to management of the CA, which can be used to issue credentials that will be generally accepted.

Encryption also presents a challenge to data availability. PKI implementations are typically robust to ensure that CAs and CRLs are always available, and there are emerging mechanisms for handling matters related to encryption keys that may provide even greater speed and reliability. Nonetheless, the risk practitioner should understand that encryption is not a fail-secure control: if keys are corrupted or lost, encrypted data will not be immediately recoverable and, in some cases, may not be recoverable at all.

Summary of the Core Concepts of Cryptography

Cryptography has many moving parts that work together in a complex series of operations. The following items summarize key information that the risk practitioner should know regarding cryptography:

- Symmetric encryption algorithms are excellent at providing confidentiality to large messages, but managing shared secret keys is difficult.
- Asymmetric algorithms are much slower than symmetric algorithms, but keys can be securely exchanged between users of asymmetric encryption using a well-established method.
- Because of the respective strengths of the two types of encryption, asymmetric algorithms are used to send symmetric keys, which are then used to encrypt messages.
- The two keys used by asymmetric algorithms (public and private) are mathematically related in a manner that lets each decrypt what the other encrypts, but it is infeasible to determine one key from the other, so public keys can be freely distributed while private keys are kept confidential.
- Hashing algorithms efficiently ensure message integrity against accidental errors by creating digests of fixed length that are mathematically linked to particular message values.
- Encrypting the hash of a message using a private key creates a digital signature that can be used to verify both message integrity and the origin of the message, which also means that the owner of the private key cannot deny sending it (nonrepudiation).
- Certificates provide assurance that the owner of a public key is who they claim to be. The assurance provided by a certificate depends on the degree to which the issuer of the certificate can be trusted.

4.9 Security/Risk Awareness and Training

Key Takeaways

- Social engineering is the most effective attack vector against enterprises today.
- People are vulnerable to social engineering and other forms of deception because they are accustomed to sharing information.
- Training and education are the main tools that enterprises have to control social engineering.

As technology has proliferated across societies around the world, the focus of information security has fundamentally shifted. The number of people whose workplace roles directly involve the use of a computer or information system is orders of magnitude higher than just a few decades ago. People are also far more accustomed to using computers (including mobile devices), networks, and data sharing services in their private lives than they were as recently as 2010. At the same time, there has been a realignment of computing resources from business to personal use. Whereas employees using computers at work once had access to systems vastly more powerful than anything usable in the home market, the average home computer today is as capable as the average work computer, while networked computing capabilities from cloud providers are available within cost ranges that even home businesses may be able to afford.

The familiarity with technology that people bring to their workplaces may reduce operation training costs and help boost productivity, but it also creates risk. As barriers to entry into the computing workspace have fallen, so have barriers to becoming cyberthreat actors. From “script kiddies” who mime the actions of professional penetration testers as a way of gaining experience to part-time dabblers in corporate espionage, all the way to foreign intelligence assets who have been recruited to launch cyberattacks from inside national borders, enterprises are faced with a bewildering threat landscape that includes more than a few operators who use basic home computing technology to carry out attacks.

Current threat actors have correctly identified human users as the weakest link in the information security foundation of modern enterprises. Security technology has improved dramatically; in contrast, human users are more vulnerable than ever. Employees accustomed to freely sharing information on social media and on their personal networks may also instinctively make information more widely available than authorized by organizational policy or seek workarounds to security features that they view as obstructing them from using computers in the manner that they would prefer to work.

Presented with realistic-looking emails or phone calls that claim to be from support or security services within the enterprise and asked to take some particular action immediately, many people are inclined to do as they are told. Worse, because of inadequate SoD and poor implementation of least privilege principles, their accounts often have the permissions within organizational systems to cause serious damage. By the time that these unwitting accomplices to cyberattacks become aware of what has happened, organizations may be facing permanent loss of data, damage to reputation, unauthorized transfers of funds or liability damages to third parties whose data has been stolen.

To counter these threats, enterprises need to educate and train their workforce on security concepts and ensure that staff members understand that system compromise creates business risk. The foremost concern should be given to teaching people to recognize social engineering techniques intended to get them to carry out tasks that benefit malicious agendas. The actual tasks tend to be simple, such as clicking a link, providing a phone number, or opening an attachment. In fact, these tasks fit into larger plans and strategies, potentially deploying malware, taking over users’ accounts, or providing leverage to reach further into an enterprise without being detected.

Making human users more resilient to the tactics of threat actors is a major purpose of security awareness and training programs, but it is not the only purpose. Human users are also the first line of defense. Properly trained, human judgment can help identify attacks in progress even when directed elsewhere. By alerting response capabilities within the organization, resilient people help create a resilient workforce, which in turn improves organizational information and cybersecurity.

Risk practitioners should review the scope of information security training and awareness programs against identified threats faced by the organization. At a minimum, the program should address these three things:

- Threats from social engineering, including deceptive emails (phishing) and calls or voicemails (vishing), which are the main threat vectors for attacks on human users
- Methods of alerting internal security capabilities such as an IT service desk or incident response team to ensure prompt notification and response to threat events

- Policies and regulatory requirements specific to the enterprise or its business sector

Leading enterprises also incorporate role-based training for administrators and others in roles that handle sensitive tasks or data as a way of mitigating role-specific risk. In addition, it is common to implement ethical phishing email exercises to assess how easy it is for employees to fall victim to a phishing scam. As a result, the enterprise can measure the level of exposed risk and the necessity of improving the awareness programs in place.

4.10 Data Privacy and Data Protection Principles

Key Takeaways

- Privacy is related to confidentiality, but a distinct discipline more closely associated with law, regulation, and data science than information security.
- Penalties for privacy violations in some jurisdictions can be enormous.
- IT risk practitioners play a role in controlling privacy risk but should recognize the limitations of their expertise and consult with privacy experts.

Privacy and data protection are increasingly important to enterprises. The prominence of these areas of concern arises partly from competitive advantage, with customers expecting rigorous protection of their data. At the same time, numerous jurisdictions have established strong laws and regulations that pertain to the handling and protection of specific classes of data. Among the most impactful is the EU General Data Protection Regulation (GDPR), which applies to data stored anywhere in the European Union and sets limits on the transfer to other jurisdictions of covered data associated with EU citizens. The GDPR establishes seven key principles:

- Lawfulness, fairness, and transparency
- Purpose limitation
- Data minimization
- Accuracy
- Storage limitation
- Integrity and confidentiality
- Accountability

Many countries have their own approaches to privacy, and multinational organizations are subject to the requirements of any jurisdiction in which they do business. As penalties associated with noncompliance increase—for instance, violations of GDPR can extend as high as 20 million Euros or 4% of an enterprise's prior-year income—enterprises are finding it increasingly important to manage these areas of risk. In the United States, health information is subject to strong protections (the Health Insurance Portability and Accountability Act [HIPAA]), while the state of California augmented a consumer privacy law similar in intent to GDPR (the California Privacy Rights Act [CPRA]).

The term "data" has traditionally been a subset term used to refer to digital forms of information. In the context of risk management, this distinction between data and information continues to apply; however, risk practitioners should be conscious that laws and regulations that deal with data privacy may also apply to information in nondigital formats. Practitioners should be aware that privacy is a dynamic field subject to regular changes and that rules applicable to certain contexts may conflict with those that apply to other contexts, including geography and types of data. Even in a cloud environment, physical storage of data may impose obligations on an organization, and international agreements are not always reliable over the long term. For instance, the US-EU "Safe Harbor" program established to facilitate compliance with GDPR was declared insufficient by a European court in 2020. Each set of laws and regulations specific to

a given context should be given appropriate study for the risk practitioner's role and responsibilities, and care should be taken to maintain currency in those areas as things change.

4.10.1 Key Concepts of Data Privacy

At its essence, privacy is very similar to confidentiality: the goal is to ensure that no one gets access to information who should not have it. Whereas confidentiality is breached when known data is revealed without approval, privacy concerns may arise from data unintentionally revealed by other data through implication or association under approved processing. Another thing that distinguishes privacy from confidentiality in practice is that an individual identified by information subject to privacy controls—the subject—has rights regarding the handling and retention of that data, even if that person is not the data owner. This distinction establishes several concepts specific to privacy that deserve the risk practitioner's awareness, which are also reflected in the seven principles of GDPR. An effective privacy program should establish clear lines of responsibility and accountability that include these concepts in a manner appropriate for the legal and business contexts in which the organization operates.

Informed Consent

Data subject to privacy regulations should be collected, used, and retained with the informed consent of the subject. A signed consent form is typically part of the process but may not be enough to establish informed consent. In addition, there may need to be a process for revocation of consent.

Privacy Impact Assessment

Organizations conduct PIAs to identify and manage risk related to privacy whenever personal information is collected. The PIA typically covers how information is used, shared, and maintained. Similar to a risk assessment, a PIA accounts for the effects of a compromise on the subject rather than impact to the enterprise. Risk practitioners dealing with data subject to privacy regulations should be familiar with the PIAs conducted prior to collecting the data as a first step toward ensuring that adequate protective measures are in place.

Minimization

Many enterprises accumulate considerable data and retain it without limit. Risk practitioners should understand that this data, which may be viewed as an asset, is also a potential disaster for enterprises subject to strong privacy regulations should a data breach occur. Privacy is best assured when only data that is expressly needed and relevant for a particular purpose is collected.

Destruction

Just as data should be collected only when necessary, it should generally be destroyed once its purpose is concluded. Destruction can be complicated, because there are some types of data that must be retained for specific periods according to law or regulation, and contractual obligations may also impose specific parameters for destruction. In this case, it is important to implement access restrictions to the data. Risk practitioners should account for destruction requirements and ensure that there are methods to carry out destruction and processes to verify that it has occurred as planned.

4.10.2 Risk Management in a Privacy Context

While legal and regulatory requirements vary, the principles of data protection that apply to confidentiality in other security contexts also tend to apply to privacy. Access to information subject to privacy considerations should be limited to individuals with a valid business need and the extent of that access should be limited according to the principle of least privilege. Many enterprises segregate duties for release of private data to serve as checks against accidental release. Strong authentication is highly recommended for access to systems hosting data covered by privacy law and this data should be encrypted at rest and in transit, with positive identification and nonrepudiation of sending authorities. Similarly, where specific

jurisdictional security requirements exist, risk practitioners should ensure that these are addressed by appropriate security controls.

Perhaps the most important function that an IT risk practitioner has in controlling privacy risk is recognizing that there may be considerations and factors beyond his or her knowledge and ability to predict. Data privacy is a comprehensive field of study involving multiple principles, frameworks, and standards in addition to legal and regulatory requirements that can vary widely from one jurisdiction to another. As mentioned previously in the case of GDPR, penalties for violations of privacy law can be enormous in some jurisdictions. Enterprises in these places will almost certainly have substantial privacy expertise on staff and are prepared to make investments in security commensurate with the potential impact. Risk practitioners assessing systems that handle sensitive personal information should consult with organizational privacy officers or privacy experts to ensure correct measures are in place for the contexts and use cases under consideration.

Case Study

Black Oak Healthcare is a mid-sized regional healthcare provider operating a network of five hospitals and 12 outpatient clinics in the Midwest region of the United States. Black Oak prides itself on providing quality patient care and operational efficiency. The organization has maintained a traditional IT infrastructure with some cloud migration over the past five years, primarily focused on nonclinical applications.

A new chief technology officer (CTO) has been appointed, and the CTO is focusing on an extensive digital transformation strategy, including the adoption of AI for diagnostic assistance, Internet of Medical Things (IoMT) devices for remote patient monitoring, and blockchain for secure medical records management.

The risk management team has been tasked with evolving their current risk governance approach to effectively incorporate emerging technology considerations while maintaining compliance with healthcare industry regulations and preserving the organization's risk culture.

1. Which of the following is the **FIRST** step Black Oak's risk management team should take to update its processes to address these technologies?

   A. Implement new controls for AI, IoMT, and blockchain.

   B. Conduct a gap analysis.

   C. Perform a risk assessment focusing on AI.

   D. Adopt the NIST AI Risk Management Framework (RMF) as the new enterprise standard.

2. What are potential risk areas where the adoption of these emerging technologies might have the **MOST** impact?
3. Which of the following represents the **MOST** appropriate approach for Black Oak to establish risk tolerance metrics for its AI diagnostic assistance technology?

   A. Accept vendor-provided risk assessments and develop metrics based on their specifications.

   B. Establish error rate thresholds based on clinical parameters and implement override controls.

   C. Apply similar availability metrics to those used for the electronic medical record system.

   D. Set a zero-tolerance policy for any AI diagnostic errors.

4. What considerations and modifications should be made for the adoption of blockchain-based medical records?

Chapter 4 Answer Key

Case Study

1. A. Implementing new controls for the emerging technologies adopted by the enterprise follows the identification and analysis of the risk posed by the use of those technologies. In order for this effort to be successful, the risk management team must identify gaps in the current risk program and existing controls.

   B. Conducting a gap analysis will help Black Oak understand the status of its current risk program and framework, identify what its future risk state is when it adopts the new technologies, and highlight specific areas where new approaches are needed. This also will help enable Black Oak to make evidence-based decisions about changes to their risk program.

   C. A new risk assessment would be conducted after current and future state decisions are made.

   D. While choosing a framework to address emerging technology is helpful, Black Oak should define its desired future state and gaps in its current processes to see which framework would be most useful and applicable to achieve this goal.

2. Possible answers include:

   - **Data/Privacy risk—**Health information is considered sensitive data, and as it is PII, regulations, such as HIPAA in Black Oak's case and GDPR in Europe, require proper handling of it. Likewise, data subjects will need to be properly informed and consent to the use of their data for these new purposes. Likewise, data storage and retention requirements should be defined, and Black Oak should ensure that blockchain can meet its needs.
   - **Ethical considerations/Human rights impact—**The use of AI, tracking, and information gathering by IoMT and handling of patient health records can all impact humans, potentially negatively.
   - **Supply chain risk—**The use of emerging and specialized technologies can lead to potential issues if vendors experience a disruption.
   - **Reputational risk—**Breaches, biased outputs, or errors have the potential for catastrophic consequences for Black Oak.

3. A. Vendor risk assessments can be helpful to understand technical specifications; however, the enterprise should validate these results independently and apply additional organizational considerations.

   B. Clinical significance provides critical information related to health diagnostics and enables risk-based decision making. This option also includes human oversight, which is crucial for AI systems that make decisions that impact humans.

   C. While metrics used for other controls can be helpful to inform controls used on similar systems, this option overlooks the unique risk and challenges posed by an AI solution.

   D. Errors occur in all systems; therefore, it is not feasible to adopt a zero-tolerance policy for AI solutions.

4. Possible answers include:

   - Operational management changes include establishing blockchain specialists within IT, creating operation-level procedures for blockchain, and developing and providing technical training for staff managing the blockchain infrastructure.
   - Risk management changes include developing specialized risk assessment methodologies for distributed ledger technologies, creating processes to validate the blockchain implementation

against regulations like HIPAA, implementing private key management, and ensuring specific audit capabilities related to blockchain or engaging external experts.

---

38 Milmo, D.; Kollewe, J.; et al.; "Slow recovery from IT outage begins as experts warn of future risks," *The Guardian*, 19 July 2024, *https://www.theguardian.com/australia-news/article/2024/jul/19/microsoft-windows-pcs-outage-blue-screen-of-death*

39 Siddiqui, Z.; "Crowdstrike update that caused global outage likely skipped checks, experts say," *Reuters*, 22 July 2024, *https://www.reuters.com/technology/cybersecurity/crowdstrike-update-that-caused-global-outage-likely-skipped-checks-experts-say-2024-07-20/*

40 Open Web Application Security Project, *www.owasp.org*

41 This may not mean *physical* proximity; the nodes on a LAN are close in terms of how they relate to one another from a routing and switching perspective.

42 TLS replaced the earlier Secure Socket Layer (SSL) protocol, and TLS VPNs are sometimes called SSL VPNs.

43 NIST, NIST *Special Publication 800-207: Zero Trust Architecture*, USA, 2020, *https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf*

44 NIST is an agency of the US government; however, many other countries reference NIST publications and frameworks or base their own frameworks on them, giving NIST outsize influence over terminology.